



NoHackHere!

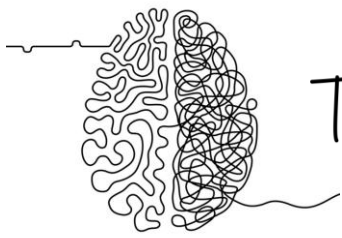
The Hackers Mindset (Persian)

By Zarvan & Chaos



The Hackers Mindset (Persian)

By Zarvan & Chaos



The *Hacker* Mindset

اطلاعات و چکیده کتاب ترجمه شده

این کتاب برات قصه نمیکه ! میکه که باید خلاق باشی و اون ذهنیت رو بیاری درون مغز خودت. هک اینجا هک اونجا هک همه جا ! تو هستی که می سازیش .

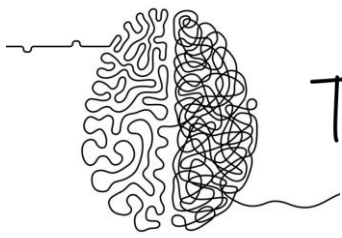
نویسنده : zarvanox01 

ویراستار : Chaos 

تاریخ انتشار : ۰۷ اردیبهشت ۱۴۰۵ 

کانال نویسنده : web_articles 

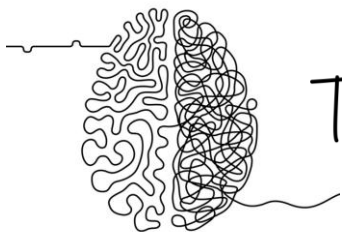
کانال ویراستار : Chaos_nexus_tech 



The *Hacker* Mindset

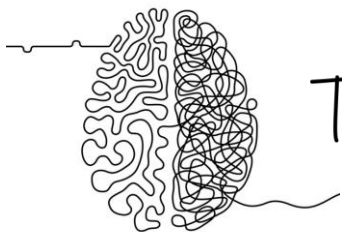
Table of Contents

5	ox00 Intro
7	ox01 The Learning Path
15	ox02 Non-Linear Learning
19	ox03 Doceo
25	ox04 Hacking with Time
28	شکست دادن ریاضی با زمان
30	از دست دادن تصویر بزرگ
34	ox05 I'm in Your House
38	ox06 No More Coffee
40	غرفه نمایشگاهی نامرئی
44	ox07 It's Not About Money
49	ox08 Cybercriminals
52	هکری که دنیا رو نجات داد
54	ox09 CVE-2022-0482
58	ox0a You Snitch
63	ox0b Yet Another XSS
67	ox0c Hacking AI
69	مهندسی اجتماعی هوش مصنوعی



The *Hacker* Mindset

71	 دانش بیش از حد
72	 مسموم سازی داده ها
73	 هک برای هدف خوب
74	 oxod SO ₂
79	 oxoe Impostor Syndrome
84	 oxof Garbage Collection
87	 About author
88	 تشکر



The *Hacker* Mindset

0x00 Intro

اون بچه‌هایی رو می‌شناسی که آرزوشون اینه وقتی بزرگ شدن بشن یه هکر واقعی؟
اینکه بشن یکی از اون آدمای باحالی که یه پنجره ترمینال باز می‌کنن، چندتا دستور تایپ
می‌کنن و یه دولت رو هک می‌کنن یا دنیا رو از شر یه تهدید هسته‌ای نجات می‌دن؟
خب، من یکی از اون بچه‌ها بودم و حدس بزن چی شد؟ آخرش یه هکر حرفه‌ای شدم.

از خودت می‌پرسی چی منو یه هکر واقعی می‌کنه؟ کلی چیز هست. بذار بگم تا
خودت انتخاب کنی:

- به من پول می‌دن تا شرکت‌ها رو هک کنم.
- من بیش از سی تا CVE کشف کردم آسیب‌پذیری‌های نرم‌افزاری که اولین کسی بودم که پیداشون کردم و عمومی اعلام کردم.
- عضو چندتا تیم هکینگ هستم، و برای عضویت باید تست‌های فنی رو پاس می‌کردم (که اساساً یعنی چیزایی رو هک کنم).



The Hacker Mindset

با اینکه همهٔ اینا واقعیت داره، ولی اینا چیزی نیست که منو به هکر می‌کنه. در واقع، اون چیزی که منو هکر می‌کنه، طرز فکره. به همین سادگی. اگه داری به این فکر می‌کنی که چطوری می‌تونی از این کتاب برای هدفی غیر از یاد گرفتن هک کردن یا فهمیدن طرز فکر به هکر استفاده کنی، یعنی همین الانم توی مسیر درست برای هکر شدن قدم برمی‌داری.

من تمام تلاشمو می‌کنم تا همهٔ اون مفاهیم کلیدی‌ای رو که خودم عاشقشون بودم یکی وقتی تازه کارمو شروع کردم بهم یاد می‌داد، توی این کتاب بگنجونم. اما این کتاب برای مخاطب فنی نوشته نشده. با اینکه راجع به یه سری موضوعات کاملاً فنی حرف می‌زنم، اما از روش دانش صفر (یعنی فرض بر اینکه که هیچی بلد نیستی) استفاده می‌کنم؛ روشی که باید حتی بعد از اینکه متخصص شدی هم حفظش کنی. در واقع، همونطور که توی فصل‌های بعدی می‌بینیم، همون چیزی که بهش می‌گیم دانش، معمولاً باعث به وجود اومدن مشکلات امنیتی، آسیب‌پذیری‌ها، پول‌های دزدیده شده، باج‌گیری، بیمارستان‌های بدون برق و کلی فرصت هکینگ دیگه میشه.

می‌بینیم که چطور هک کردن به فرآیند فنی نیست، بلکه به فرآیند خلاقانه‌ست. می‌بینیم که چطور لازم نیست به متخصص آی‌تی باشی تا به کار بردن طرز فکر هکری تو زندگی روزمره، دست بیاد. ما چیزی رو می‌بینیم که دیگران نمی‌بینن.

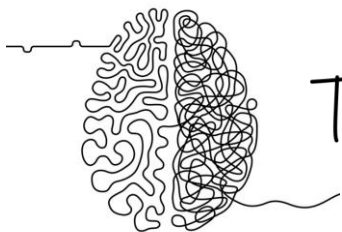


The Hacker Mindset

این یه پارادوکس جذابه که ارزش داره همین اول کار بهش فکر کنیم، معمولاً ما فکر می‌کنیم دانش بیشتر یعنی امنیت بیشتر. اما تو دنیای هکینگ، ماجرا برعکسه. هرچی یه سیستم پیچیده‌تر میشه و افراد بیشتری روش کار می‌کنن، نقاط کور بیشتری هم توش به وجود میاد. فرضیات اشتباه، اعتماد بیش از حد به منطق خودمون، و باور به اینکه این قسمت رو که همه بلدن و درست نوشتیم، دقیقاً همون چیزیه که یه هکر انتظارش رو می‌کشه. برای همینم هست که بهترین هکرها همیشه یه ذهن مبتدی رو حفظ می‌کنن؛ ذهنی که همه چی رو زیر سؤال میبره و حتی ساده‌ترین چیزایی که بقیه ازش رد می‌شن رو هم زیر سوال می‌بره. تو این کتاب قراره با هم تمرین کنیم که چطور این نگاه رو تو خودمون زنده نگه داریم.

0x01 The Learning Path

به نظر می‌رسه آدم‌ها با مسیرهای یادگیری خیلی راحت‌ان. وقتی می‌ری دبستان، یه برنامه درسی قشنگ و مرتب برات طراحی می‌کنن تا یه پایه محکم بهت بدن. بهت ریاضی، زبان، علوم و هنر یاد می‌دن و آماده‌ت می‌کنن برای مرحله بعد، جایی که، حدس بزن چی میشه، یه مسیر مطالعاتی دیگه با موضوعای خیلی شبیه به همون قبلیا پیدا می‌کنی.



The Hacker Mindset

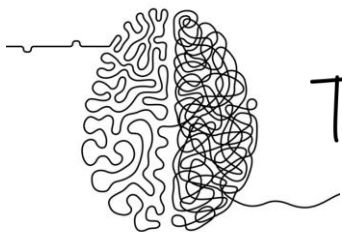
این قضیه همینجوری ادامه پیدا می‌کنه، تا برسه به دوره‌های کارشناسی و دکتری، جایی که حتی از برنامه درسیشون برای تبلیغ خودشون استفاده می‌کنن. حتی تو مدرسه‌های خصوصی (چه فوق‌لیسانس باشه چه یه دوره تخصصی)، یکی از شعارهای همیشگی اینه که قدم به قدم راهنمایت می‌کنیم تا به موفقیت برسی.

مردم فکر می‌کنن برای همه چی یه فرمول وجود داره، که آدم باید یه لیست مشخص از چیزا رو بدونه تا دکتر بشه، آشپز بشه، مهندس بشه و الی آخر. و خب، این تو بعضی موارد درسته.

اما در عین حال، بذار یه حقیقت دیگه رو هم بهت بگم مسیر یادگیری، در واقع خودش مشکلِ کاره.

اینکه کل زندگیمون رو صرف پریدن از یه موضوع به موضوع دیگه بکنیم، همیشه روی یه چیز خیلی خاص تمرکز کنیم، فقط چیزایی رو یاد بگیریم که برای قبول شدن تو امتحان یا انجام تکلیف مدرسه لازم داریم، یه مشکلی داره و اونم اینه که تو ما یه جور دید تونلی ایجاد می‌کنه، جوری که یه بخش بزرگ از طیف اطرافمون رو اصلاً نمی‌بینیم.

کلی تحقیق علمی برای حمایت از این نظریه وجود داره. مثلاً، سال ۱۹۹۹ روانشناسای محقق، سایمونز و شایریرس، یه ویدئو درست کردن که توش یه سری دانشجو یه توپ بسکتبال رو بین خودشون پاس می‌دن و از بیننده‌ها خواستن تعداد پاس‌ها رو بشمرن.

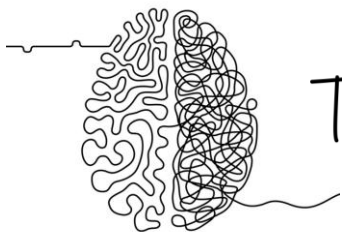


The Hacker Mindset

بعضیا درست شمردن، بعضیا اشتباه. اما از همه مهمتر، تقریباً ۵۰ درصد مردم اصلاً متوجه یه آدم با لباس گوریل نشدن که میاد وسط تصویر و کلی کار انجام میده البته، این ربطی به مسیرهای یادگیری نداره، اما یه مدرک محکمه که وقتی ذهن ما بیش از حد روی یه کار خاص متمرکزه، خیلی از واقعیت‌های عیان دیگه رو از دست میده. و راحت می‌شه تصور کرد که اگه کل زندگیمون رو روی یه امتحان، یه موضوع یا یه هدف خاص متمرکز کنیم، تو وجود خودمون یه میل به دید تونلی، کوری تغییر و شکل‌های دیگه‌ای از درک ناقص پرورش می‌دیم. یعنی همون حالتی که ذهنمون انقدر باریک و متمرکز میشه که تغییرات آشکار دور و برمون رو نمی‌بینه و واقعیت رو جور دیگه‌ای تفسیر می‌کنه. درست مثل تماشاگرای اون ویدیو که اینقدر غرق شمردن پاس‌ها بودن که یه گوریل رو از وسط تصویر ندیدن.

این شکل از دید تونلی، اثرات غم‌انگیزی روی زندگی واقعی داره و عمیقاً با دنیای هکینگ مرتبطه. در واقع، خیلی از آسیب‌پذیری‌ها کاری نمی‌کنن جز اینکه از منطق ناقص و معیوب سوءاستفاده کنن؛ چون یه باگ امنیتی، درست از همون جایی وارد میشه که فکر برنامه‌نویس بهش نرسیده.

بذار با یه مثال بهتر بگم. فکر کنم هممون یادمو نه ۱۱ سپتامبر ۲۰۰۱ چی شد. یه گروه تروریست هواپیماهای مسافربری رو ربودن و به برج‌های دوقلو تو نیویورک کوبیدن و



The Hacker Mindset

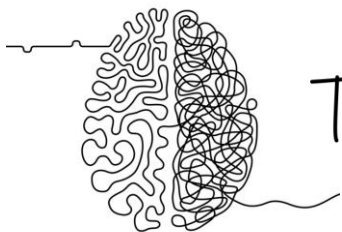
هزاران آدم بی گناه رو کشتن. اون خیلی غم انگیز بود، معلومه، و باعث تغییرات زیادی تو سیاست‌های امنیتی هواپیماها شد.

یکی از اون تغییرات این بود که مطمئن بشن کابین خلبان وقتی از داخل بسته‌ست، غیرقابل نفوذ تا هیچ آدم غیرمجازی نتونه به بخش کنترل هواپیما دسترسی پیدا کنه، خلبان‌ها رو بکشه و کنترل هواپیما رو به دست بگیره. عالیه دیگه چه مشکلی ممکنه پیش بیاد؟

مطمئنم این کار با بهترین نیت‌ها انجام شده، اما در نظر نگرفته بود که چطور میشه از این قابلیت برای اهداف خرابکارانه استفاده کرد. ۲۴ مارس ۲۰۱۵، تو پرواز ۹۵۲۵ جرمونینگز، خلبان (که ظاهراً قبلاً برای داشتن تمایلات خودکشی تحت درمان بوده) خودش رو تو کابین فرماندهی حبس کرد و عمداً هواپیما رو با ۱۵۰ سرنشین به زمین کوبید و همشون رو کشت.

اون صبر کرد تا کمک‌خلبان‌ش بره دستشویی، و خودش رو به تنهایی تو کابین حبس کرد، جویری که هیچ کس نمی‌تونست در رو از بیرون باز کنه. این کار به خاطر همون مکانیزم امنیتی‌ای ممکن شد که بعد از فاجعه ۱۱ سپتامبر معرفی شده بود.

شرمنده‌ام که مجبورم ذهنت رو ببرم سمت اون فاجعه‌ها، ولی این یکی از قوی‌ترین مثال‌هایی بود که از اشتباهات ناشی از دید تونلی می‌شناختم. بعد از این فاجعه جدید،



The Hacker Mindset

حتی یکی پیشنهاد داد این مشکل جدید رو با این حل کنن که قابلیت کنترل از راه دور هواپیماها رو فعال کنن... لطفاً این کار رو نکنین.

به عنوان مترجم نیاز هست این رو اضافه کنم یه نمونش توی کشور خودمون رخ داده متأسفانه. بخاطر جنگ اومدن اینترنت رو ملی کردن بعد یکی از دلایلشون این هست که میخوان جلوی ارسال تصاویر و ویدیو توسط جاسوس های موساد رو بگیرن.

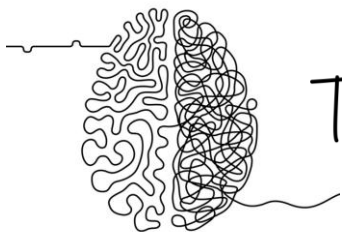
یعنی موساد اینقدر ضعیف هست که نمیتونه اینترنت جاسوس هاش رو تأمین کنه؟
بعد گذشته از همه اینا پس چرا دارن vpn میفروشن اونم به قیمت هر گیگ ۱ تا ۲ میلیون
بعد این موضوع مشکلی نداره و جلوش گرفته نمیشه؟

خب جاسوس های موساد یعنی نمیتونن یک گیگ بخرن بعد ارسال کنن؟

حالا تکلیف اشخاصی مثل ما که زندگیمون به اینترنت گره خورده چیه؟

گذشته از همه اینا به هر دلیلی که اینترنت رو ملی کردن کار نداریم چون بحث امنیت ملی هست دیگه. پس چرا دارن اینترنت پرو ارائه میکنن؟ یعنی با اینترنت پرو همیشه دیگه جاسوسی کرد؟

این میشه یه نمونه از دید تونلی توی کشور خودمون.



The Hacker Mindset

منظورم اینه که یه دید محدود به یه موضوع، قابلیت یا محصول می‌تونه کلی مشکل ایجاد کنه، که البته خوشبختانه از اون مثال‌های بالا غم‌انگیزتر نیستن. وقتی ۲۱ سالم بود، پدر و مادرم کمکم کردن یه ماشین نو بخرم، یه ماشین R (بیخشید، مجبورم اسم برند رو سانسور کنم). راستش انتخاب اولمون نبود، ولی فروشنده‌مون پیشنهادش کرد، و ماشین بزرگ و برّاقی بود، پس معامله رو انجام دادیم. ماشین یه قابلیت جدید و باورنکردنی هم داشت (برای اون دوران) یه کلید هوشمند.

این کلید به طرز شگفت‌انگیزی باهوش بود و به راننده اجازه می‌داد ماشین رو باز کنه و روشنش کنه بدون اینکه کلید رو از جیبش درآره. وای، چه ابزار محشری دوستانم تعجب کرده بودن. حیف که این سیستم، حتی اگه من دور و بر ماشین بودم و یکی دیگه در رو باز می‌کرد، دکمه استارت رو می‌زد و با ماشین من فرار می‌کرد هم کار می‌کرد. دوستانم این کارو بارها کردن.

احتمالاً مهندسای پژو 405، اونقدر روی تجربه کاربری و اون آرزوی اینکه مجبور نباشی هیچوقت سوئیچ رو از جیب درآری و از این ماشین بدون کلید لذت ببری متمرکز شده بودن که تمرکزشون رو روی جنبه‌های امنیتی از دست دادن. در واقع، ماشینم بعد از چند ماه دزدیده شد و منو خیلی غمگین کرد.

من کل این فصل رو در مورد مسیرهای یادگیری حرف زدم فقط برای اینکه این نکته رو برسونم که برای پرورش یه طرز فکر هکری، باید از این چارچوب ذهنی فراتر بری.



The Hacker Mindset

باید یاد بگیری چطور ذهنت رو از الگوها و چهارچوب‌های از پیش تعیین شده رها کنی و سعی کنی خارج از چارچوب فکر کنی. باید به ذهن و افکارت جرات و جسارت بدی. مسیر یادگیری ما، هیچ مسیر از پیش تعیین شده‌ای نخواهد داشت.

حالا شاید با خودت بگی این حرفا قشنگه، ولی چطور میشه واقعاً از این چارچوب ذهنی فرار کرد؟ چطور میشه ذهنی رو پرورش داد که به جای دنبال کردن یه مسیر مشخص، خودش مسیر خودش رو بسازه؟

جواب کوتاهش اینه:

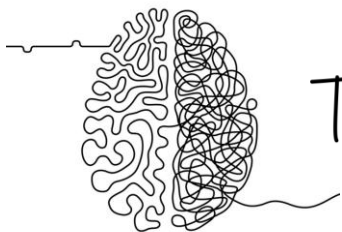
یاد بگیر که چطور یاد بگیری، نه اینکه چی یاد بگیری. این یه تفاوت ظریف اما حیاتیه. آدمایی که ذهن هکری دارن، معمولاً آدمایی نیستن که بیشترین مدرک رو دارن یا بیشترین دوره‌های آموزشی رو گذروندن. اونا کسانی هستن که یاد گرفتن چطور سوال پرسن، نه اینکه فقط جواب حفظ کنن. یه ذهن هکری وقتی به یه سیستم نگاه می‌کنه،

نمی‌پرسه این چطور کار می‌کنه؟

می‌پرسه اگه این کار رو نکنم چی میشه؟

اگه این ورودی رو عوض کنم چی؟

سازنده این سیستم به چی فکر نکرده؟

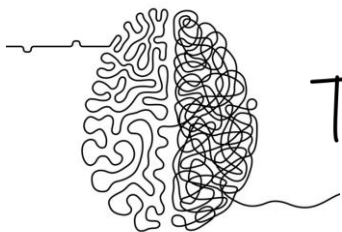


The Hacker Mindset

این نوع نگاه رو همیشه تو هیچ برنامه درسی رسمی پیدا کرد. چون سیستم‌های آموزشی طوری طراحی شدن که بهت بگن مسیر درست اینه، از این راه برو. اما یه هکر می‌دونه که همیشه یه راه فرعی هم هست، یه در پستی، یه پنجره باز که هیچ کس حواسش بهش نیست. برای همینم هست که بعضی از بهترین هکرها دنیا، آدمایی هستن که هیچوقت تحصیلات آکادمیک نداشتن، یا اگه داشتن، نصفش رو ول کردن و دنبال کنجکاوی خودشون رفتن. حالا از فردا درس ول نکنید که بهونه اینکه می‌خوایید تفکر هکری پیدا کنید.

واقعیت اینه که مدرسه و دانشگاه بهت یاد می‌دن چطور تو چارچوب فکر کنی. بهت مسئله می‌دن و ازت می‌خوان با فرمولی که یادت دادن حلش کنی. اما زندگی واقعی، و مخصوصاً دنیای هکینگ، اینطوری نیست. تو زندگی واقعی، مسئله‌ها از قبل تعریف شده نیستن. خودت باید پیدااشون کنی. خودت باید بفهمی که اصلاً سوال چیه، نه اینکه جواب چیه. این دقیقاً همون چیزیه که یه ذهن غیرخطی انجام میده: اول سوال رو پیدا می‌کنه، بعد می‌ره دنبال جواب.

پس اگه می‌خوای ذهن هکری رو تو خودت پرورش بدی، شروع کن به شک کردن به چیزایی که بقیه به عنوان بدیهیات قبول کردن. از خودت بپرس چرا؟ و چرا که نه؟ هر چیزی که بهت می‌گن همینه که هست، رو زیر سوال ببر. این کار تو ابتدا شاید عجیب و حتی آزاردهنده به نظر برسه، ولی بدون که این اولین قدم برای دیدن چیزاییه که دیگران



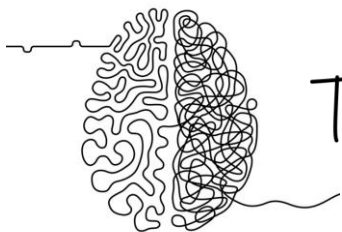
The Hacker Mindset

نمی‌بینن. و این، همونطور که تو فصل‌های بعدی می‌بینیم، نه فقط برای هک کردن سیستم‌ها، بلکه برای هک کردن زندگی هم به کار میاد.

0x02 Non-Linear Learning

باید بهت بگم، راه سخت و دشواریه. واقعاً توضیح دادن و یاد دادنش هم خیلی مشکله، اونقدر که من خودم رو مناسب این کار نمی‌بینم. خبر خوب اینه که لازم نیست هم مناسب باشم. یادگیری بدون مسیر یادگیری، اسم دیگه‌اش میشه یادگیری غیرخطی، و جالبه بدونین که این یه تناقض درونیه، چون خودش یه روشه برای یادگیری بدون روش قرار نیست عمیق‌تر وارد این مفهوم بشم، چون یه ایده کلی بهت دادم، ولی خوشحال می‌شم اگه به نظرت جالب یا باارزش میاد، بری و خودت بیشتر راجع بهش یاد بگیری. در غیر این صورت، الان به اندازه کافی می‌دونم که بتونی جلو بری. همین حالا، داری به صورت غیرخطی یاد می‌گیری.

من یه نویسنده کتاب نیستم، اما دارم این کتاب رو می‌نویسم، که البته دومین کتابمه (اگه بتونم تمومش کنم). من این کار رو با تکیه بر صدها کتابی که خوندم، دانشی که در طول تحقیقات فنی‌ام به دست آوردم و چند پست وبلاگی که در طول چند سال گذشته نوشتم، دارم با عمل کردن و حین انجام کار یاد می‌گیرم. من از سبک نوشتاری یا تکنیک‌های داستان‌گویی هیچی سر در نمی‌ارم، و حتی انگلیسی هم زبان مادریم نیست،



The Hacker Mindset

ولی با این همه کتاب داره شکل می گیره. این روش منه برای یاد گرفتن کتاب نوشتن،
یه روش غیرخطی.

وقتی بحث هکینگ پیش میاد، این مفهوم حتی مهم تر هم میشه، چون دقیقاً ابرقدرت یه
هکر همینه استفاده از اطلاعاتی که در دسترس همه ست و ترکیب دوباره شون برای
رسیدن به نتیجه ای که هیچ کس قبلاً بهش نرسیده. تو می تونی لپ تاپت رو باز کنی و همه
دوره های هکینگ موجود تو اینترنت رو بگذرونی تا این چیزا رو یاد بگیری:

- مبانی شبکه های کامپیوتری
- چطور یه فایل باینری (کامپایل شده) رو مهندسی معکوس کنی
- چطور عمیقاً وارد مبحث XSS بشی، که یکی از رایج ترین آسیب پذیری های وبه
- رمزنگاری و شکستن رمزنگاری

و من می تونم تا ابد با کلی کلمه قلمبه سلمبه جذاب ادامه بدم که اگه بخوای یه هکر
کامپیوتر بشی خیلی هم باحالت، اما این حوزه های مطالعاتی بهت کمک نمی کنن تا طرز
فکر هکری رو توی خودت پرورش بدی؛ همون مهارت ناملموسی که بهت اجازه میده
از اطلاعاتی که همین الانم داری، چیز بیشتری به دست بیاری.

یادگیری غیرخطی شامل یه سری جرقه ها، اتفاق ها و خاطرات میشه که باعث میشن عاشق
یه چیزی بشی و دنبالش کنی. بهش می گن غیرخطی چون شکلش بیشتر شبیه یه تار



The Hacker Mindset

عنکبوت، یه شبکه‌ای از ارتباطات تصادفی، یه شبکه‌ای که می‌تونه خودش رو دوباره شکل بده و یهوئی از هیچ‌جا یه ایده ناب رو خلق کنه. و اگه الان احساس گیجی می‌کنی، این یه خبر عالیه ذهن غیرخطی هیچوقت از آشفتگی و بی‌نظمی نمی‌ترسه بلکه آغوشش رو براش باز می‌کنه. اگه حس می‌کنی برای در آغوش کشیدن آشفتگی خودت آماده نیستی، پس آماده باش آشفتگی منو پذیری، چون توی فصل‌های بعدی دقیقاً با همین مواجهه میشی.

حالا شاید از خودت بپرسی باشه، قبول که یادگیری غیرخطی قشنگه، ولی از کجا باید شروع کنم؟ و این دقیقاً همون سوالیه که یه ذهن خطی می‌پرسه. چون عادت کردیم همیشه یه نقطه شروع مشخص، یه نقشه راه و یه مقصد نهایی داشته باشیم. اما یادگیری غیرخطی اینطوری کار نمی‌کنه. تو از وسط ماجرا شروع می‌کنی، از یه جرقه، از یه کنجکاوی ساده، از یه سوال که یه شب تو تخت خواب به ذهنت می‌رسه. بعدش دنبالش می‌ری، نه برای اینکه به جواب برسی، بلکه برای اینکه ببینی این سوال تو رو به کجا می‌کشونه. و تو این فرآینده که یادگیری واقعی اتفاق می‌افته.

نکته جالب اینجاست که خیلی از بزرگترین کشف‌های علمی و تکنولوژیک تاریخ، نتیجه همین نوع یادگیری بودن. پنی‌سیلین رو Alexander Fleming تصادفی کشف کرد، چون داشت با باکتری‌ها بازی می‌کرد و یهو یه کپک عجیب توجهش رو جلب کرد. مایکروویو رو Percy Spencer موقع کار روی رادار کشف کرد، وقتی دید یه

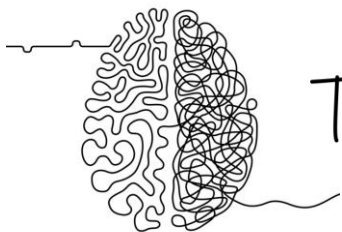


The Hacker Mindset

شکلات تو جیش آب شده. هیچ کدومشون دنبال این کشف‌ها نبودن، ولی ذهنشون به اندازه کافی باز بود که وقتی به اتفاق غیرمنتظره افتاد، به جای اینکه نادیده‌اش بگیرن، کنجکاو بشن و دنبالش کنن. این یعنی ذهن غیرخطی در عمل.

تو دنیای هکینگ هم داستان همین. خیلی از معروف‌ترین آسیب‌پذیری‌ها و خلاقانه‌ترین حمله‌ها، نتیجه دنبال کردن به هدف خاص نبودن. هکر داشت به کار دیگه می‌کرد، به چیز عجیب دید، و به جایش اینکه رد بشه، ایستاد و با خودش گفت عجیبه... بذار بینم این چیه. این مکث کردن سر چیزای عجیب و غیرمنتظره، همون چیزیه که ذهن غیرخطی رو از ذهن خطی جدا می‌کنه. ذهن خطی می‌گه این به هدفم ربطی نداره، پس اهمیت نده. ذهن غیرخطی می‌گه صبر کن بینم، این چرا اینجوریه؟

پس اگه می‌خوای این مدل یادگیری رو شروع کنی، لازم نیست حتماً به برنامه مشخص داشته باشی. فقط کافیه اجازه بدی کنجکاویت هدایت کنه. به موضوع پیدا کن که واقعاً برات سوال برانگیزه، نه اینکه فکر کنی باید یادش بگیری. بعدش برو دنبالش، بدون اینکه بدونی قراره به کجا برسی. تو مسیر، چیزای دیگه‌ای هم پیدا می‌کنی، و اونا هم تو رو به سمت چیزای دیگه‌ای می‌کشونن. این تار عنکبوت هی بزرگ و بزرگ‌تر میشه، و تو به روز به خودت می‌ای و می‌بینی که کلی چیز بلدی که هیچوقت تو هیچ دوره آموزشی‌ای درس داده نشده. این یعنی یادگیری غیرخطی. و این دقیقاً همون مسیری که ما تو این کتاب باهم می‌ریم.



The Hacker Mindset

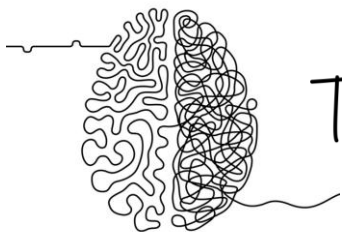
0x03 Doceo

هر کتاب هکینگی که احترام داشته باشه، با همون اولین هک معروف شروع میشه. (منظور نویسنده اینه که کتاب‌های هکینگ معمولاً با داستان اولین تجربه هک خود نویسنده شروع می‌شن.)

اوه... الان بعد از چندین صفحه حرف زدن از اینکه الگوها چطور خلاقیت و دید ما رو نابود می‌کنن، دارم از یه الگو پیروی می‌کنم؟ نه واقعاً، دلیلش ساده‌س این اتفاق هجده سال پیش افتاد و من فقط یه ماه پیش که شروع به نوشتن این کتاب کردم، فهمیدم که این اولین هک زندگیم بوده.

من به عنوان یه دانش آموز جوون، دبیرستان علمی می‌رفتم و با کامپیوتر نسبتاً خوب بودم نه به طرز باورنکردنی‌ای باهوش، ولی قطعاً بالاتر از حد متوسط.

یه روز سر کلاس فلسفه، یه نفر حرف استاد رو قطع کرد تا بهش بگه که متأسفانه، یه مشکلی برای کامپیوتر مدرسه پیش اومده (اون موقع‌ها مدرسه ما خیلی کم کامپیوتر داشت) و مقاله‌های باارزش مجله اینترنتی‌ش پاک شدن. اون خیلی عصبانی بود چون براش اون پروژه اهمیت زیادی داشت، و من یه فرصت رو اون وسط دیدم. یاد حرف دوستم نیکولا افتادم (اون واقعاً یه نابغه کامپیوتر بود) که بهم گفت: برای اینکه واقعاً اطلاعات رو از رو هارد دیسک پاک کنی، باید چندین بار پاکشون کنی و روشون



The Hacker Mindset

اطلاعات جدید بنویسی تا مطمئن بشی هیچی رد و نشونی از شون باقی نمونه. ممم...
ممکنه این معنی اش این باشه که اطلاعات استادم قابل بازیابیه؟ می خواستم ریسکش رو
بکنم

دستم رو بلند کردم و بهش گفتم که احتمالاً بتونم اطلاعاتش رو برگردونم. جوابش این
بود: خب پس چرا هنوز اینجاایی؟ برو رفتم به کتابخونه، جایی که یکی از کامپیوترهای
اصلی مدرسه اونجا بود. اون دستگاه ظاهراً کلاً از کار افتاده بود و موقع بالا اومدن با یه
خطای مرگبار کرش می کرد. من اونو تو حالت بازیابی (Recovery Mode)
راه اندازی مجدد کردم؛ یه رویه ای که فقط قطعات ضروری برای روشن شدن ماشین رو
بارگذاری می کنه و معمولاً برای حل این جور مشکلات جواب میده، چون بقیه
نرم افزارهایی که معمولاً عامل اصلی کرش هستن رو بارگذاری نمی کنه. جواب داد،
شروع خوبی بود بعدش، یه راه اندازی مجدد عادی انجام دادم، یه نرم افزار بازیابی
اطلاعات (که ابزاریه برای برگردوندن فایل ها بعد از اینکه پاک شدن یا در اثر یه خرابی
سخت افزاری خراب شدن) دانلود کردم و یه اسکن کامل شروع کردم.

یه نکته حاشیه ای: معلوم شد که پاک کردن دائمی یه فایل از کامپیوتر، سخت تر از چیزیه
که فکر می کنیم. به همینه که اف بی آی، سیا و سازمان های مشابه می تونن فایل های چند
ساله رو از گوشی ها و لپ تاپ های ضبط شده بیرون بکشن.

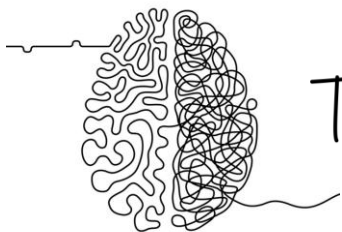


The Hacker Mindset

در کمال تعجبم، برنامه مثل یه جادو کار کرد و من تونستم همه فایل‌های استاد رو برگردونم خوشحال و مغرور، برگشتم به کلاس و خبر خوب رو بهش دادم. اون موقعیت باعث شد احترام استاد رو جلب کنم و نمره‌های بهتری تو تاریخ و فلسفه بگیرم. اما، نه. این اون اولین هکی نبود که می‌خواستم تو این فصل درموردش بهت بگم. حتی اگه به این معنا باشه که، نمره‌های دو درس رو که توش زیاد خوب نبودم هک کرده باشم، داستان اینجا تموم نمیشه.

من همه کار رو روی کامپیوتر مدرسه و تحت نظر مسئول کتابخونه انجام دادم. اون متوجه شد که من با کامپیوتر خوش‌دستم و ازم پرسید می‌تونم یه سری بازی کارتی (مثل بلک‌جک) هم روی اون دستگاه نصب کنم تا اونم سرش گرم بشه و وقتش خوش بگذره. نپرس چرا، ولی من گفتم باشه و پرسیدم کار دیگه‌ای هم روی اون کامپیوتر هست که نیاز به تعمیر داشته باشه؟ جوابش این بود: تنها چیزی که به فکر می‌رسه، ایمیل مدرسه‌ست.

و این شد شیرین‌کاری من. سرویس ایمیل کار می‌کرد، ولی من بهش گفتم که کار نمی‌کنه و برای اینکه دوباره راه‌اندازیش کنم، به رمز عبورش نیاز دارم. جوابش: حتماً، رمز عبورش هست دوستو (doceo). از همون لحظه به بعد، من صاحب اصلی‌ترین و تنها آدرس ایمیل مدرسه بودم، و حتی می‌تونستم از خونه هم مدیریتش کنم. تو اصطلاحات هکینگ، به این می‌گن مهندسی اجتماعی؛ یعنی وقتی طرف رو گول می‌زنی

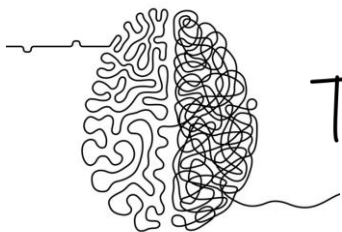


The Hacker Mindset

تا اطلاعات حساسی رو که قرار نیست تو داشته باشی، لو بده. مهندسی اجتماعی یکی از قوی‌ترین حملات و از اون مدل حملاتی که من از همه کمتر دوستش دارم، چون از آدم‌ها سوءاستفاده می‌کنه که معمولاً ضعیف‌ترین حلقه تو یه زنجیره امنیتی هستن.

چک کردن ایمیل مدرسه با قهوه صبحگاهی‌م شد یه روتین، ولی هیچوقت هیچ خسارت واقعی وارد نکردم، و هیچوقت ایمیلی به اسم مدرسه نفرستادم. فقط بهم یه حس هیجان می‌داد. چند بار بعضی ایمیل‌ها رو قبل از اینکه کارکنای مدرسه بخونن پاک کردم، قالب خام کارنامه‌ها رو دانلود کردم و به یکی از دوستانم که نیاز به یه دستکاری داشت دادم، و حتی صبح روز امتحان نهایی ایمیل رو چک کردم به این امید که شاید سوالای امتحان رو ایمیل کرده باشن... ولی نکرده بودن.

می‌دونم کاری که کردم غیرقانونیه و کار خیلی بدی هم بود، ولی فقط هفده سالم بود. اشتباه کردم و متاسفم. با نمره‌های متوسط فارغ‌التحصیل شدم و به زندگیم ادامه دادم، ولی حدود یه سال بعد، توی اتاق خوابم، تیکه کاغذی رو پیدا کردم که روش رمز و ایمیل مدرسه رو نوشته بودم، برای همین دوباره سعی کردم وارد شم. و البته که هنوز کار می‌کرد.

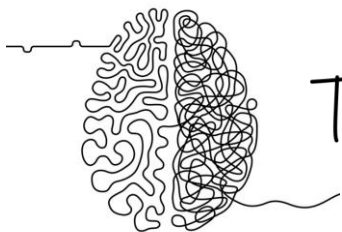


The Hacker Mindset

این داستان، فراتر از یه خاطره بامزه یا یه اعتراف ساده‌ست. این یه نمایش کامل از سه تا از بنیادی‌ترین مفاهیم دنیای هکینگه که تو یه اتفاق واقعی و به‌ظاهر ساده جمع شدن: تشخیص فرصت، مهندسی اجتماعی، و حفظ دسترسی.

اولیش تشخیص فرصت بود. ببین چطور همه چی از یه مشکل شروع شد که به من ربطی نداشت. استادم فایل‌هاش رو از دست داده بود، و من می‌تونستم مثل بقیه دانش آموزا فقط تماشا کنم و متاسف باشم. اما یه چیزی تو ذهنم جرقه زد. اون حرف دوستم رو به یاد آوردم، و یهو یه ارتباط بین یه مفهوم تئوری (نحوه پاک شدن فایل‌ها) و یه مشکل واقعی دیدم. این همون لحظه‌ایه که ذهن هکری وارد عمل میشه: دیدن یه فرصت در دل یه بحران. برای دیگران، یه فاجعه بود. برای من، یه معما بود که می‌خواستم حلش کنم.

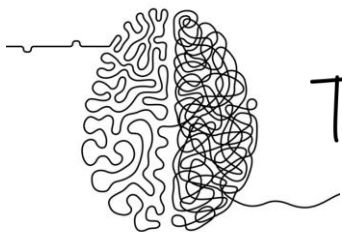
دومین مفهوم، و شاید مهم‌ترینش، مهندسی اجتماعی بود. این رو صریح گفتم، ولی بذار عمیق‌تر بازش کنیم. مهندسی اجتماعی فقط دروغ گفتن یا گول زدن نیست. یه هنره. هنر فهمیدن این که آدم‌ها چطور فکر می‌کنن، به چی اعتماد دارن، و چطور تصمیم می‌گیرن. من به مسئول کتابخونه دروغ نگفتم که من رئیس جمهورم یا از طرف پلیس اومدم. من فقط یه داستان ساده و باورپذیر گفتم ایمیل کار نمی‌کنه، باید دوباره راه‌اندازیش کنم. این داستان رو هم از موضع یه آدم خیرخواه گفتم که داره کمک می‌کنه. اونم بدون هیچ سوالی پسورد رو داد. چرا؟ چون اعتماد کرد. چون من رو یه بچه مثبت و کمک‌کننده دیده بود که تازه فایل‌های استاد رو نجات داده بودم. من از اعتماد



The Hacker Mindset

ساخته شده در مرحله قبل، به عنوان پلی برای مرحله بعد استفاده کردم. این یعنی مهندسی اجتماعی حرفه‌ای: ساختن یه روایت که قربانی بخواد بهت اعتماد کنه.

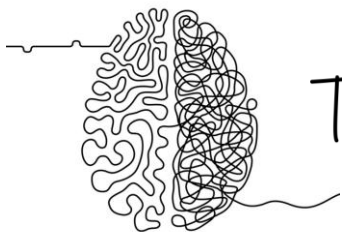
و سومی حفظ دسترسی بود. ببین، حتی یه سال بعد هم رمز عبور عوض نشده بود. این رو دست کم بگیر. تو دنیای واقعی، خیلی از شرکت‌ها و سازمان‌ها همین قدر شلخته هستن. یه آسیب‌پذیری وصله میشه، اما یه رمز عبور قدیمی، یه حساب کاربری فراموش شده، یا یه راه پشتیبان که کسی حواسش بهش نیست، برای سال‌ها دست نخورده باقی می‌مونه. به این می‌گن Persistence یا پایداری. هک‌های حرفه‌ای بعد از نفوذ، همیشه دنبال راهی می‌گردن که بتونن برگردن. من ناخودآگاه این کار رو کردم، با ننگه داشتن اون تیکه کاغذ. و این درس بزرگیه: گاهی بزرگترین تهدیدها، چیزایی نیستن که همین الان دارن اتفاق می‌افتن، بلکه چیزایی هستن که ماه‌ها و سال‌ها بعد، از یه روزنه فراموش شده، دوباره سر باز می‌کنن. این داستان ساده دوران دبیرستان، عملاً یه دوره فشرده از سه رکن اصلی یه حمله سایبری واقعی بود، که من در ۱۷ سالگی و فقط با دنبال کردن کنجکاوی و غریزه‌ام اجراش کردم.



0x04 Hacking with Time

هرچقدر هم که دلم می‌خواد با شرح حال خودم برم جلو، فکر نمی‌کنم این دلیلی باشه که داری این کتاب رو می‌خونی. به علاوه، یه چیز خیلی جذاب‌تر دارم که می‌تونیم درموردش حرف بزنیم اونم زمان هست. به نظر من، زمان یکی از شگفت‌انگیزترین مفاهیم دنیاست. دانشمندا و فیلسوفا هزاران ساله سعی دارن توضیحش بدن، از زوایای مختلف به مسئله حمله کردن و حتی درباره وجود داشتنش هم بحث کردن. در واقع، تئوری‌هایی هست که می‌گن زمان اصلاً وجود نداره، زمان وجود داره ولی جاری نمیشه (بلکه این ماییم که توی زمان حرکت می‌کنیم)، و اینکه گذشته، حال و آینده همه درست تو یه لحظه، به صورت موازی در حال رخ دادن هستن.

امروز می‌خوایم ببینیم چطور زمان می‌تونه وقتی بحث هکینگ میشه، یه ابزار قدرتمند باشه، اونقدر مخرب که می‌تونه یه شرکت رو به ورشکستگی بکشونه. همین چند هفته پیش داشتم نرم‌افزار یه شرکتی رو بررسی می‌کردم که جشنواره‌های موسیقی بزرگ برگزار می‌کنه. یه قابلیتی توش بود که به مردم اجازه می‌داد به یه پیشنهاد رویداد رای مثبت بدن، تا به برگزارکننده‌ها کمک کنه بهتر سلیقه و علاقه به یه نوع هنرمند یا موسیقی خاص رو بفهمن. این موضوع بلافاصله زنگ خطر رو تو ذهن من به صدا درآورد، و از برنامه‌نویس ارشدشون پرسیدم این قابلیت چطور پیاده‌سازی شده. جواب داد که اونا خیلی ساده تعداد کل آرای مثبت رو به صورت یه عدد صحیح (مثلاً ۵۷۶) ذخیره



The Hacker Mindset

می‌کنن، و وقتی یه رای جدید میاد، بهش اضافه می‌کنن (+۱) و کل عدد رو بازنویسی می‌کنن.

ساده و سرراسته، نه؟ غلطه این دقیقاً همون مدل پیاده‌سازی‌ایه که در برابر حمله‌های Race Condition آسیب‌پذیره. زمان عاملیه که مجبوری موقع نوشتن یه سری فرآیند خاص در نظر بگیری، چون حتی همون جمع ساده‌ای که بالا توضیح دادم هم یه کمی طول می‌کشه تا اجرا بشه. برای سادگی بگیریم که این کار ده میلی‌ثانیه طول می‌کشه. تصور کن یه رای بیاد، و بعد یه رای دیگه فقط دو میلی‌ثانیه بعدش بیاد، و رای اولی هنوز اجراش تموم نشده باشه، پس عدد کل هنوز به‌روزرسانی نشده. هر دو رای، عدد شروع یکسانی رو می‌بینن و هر دو، عدد کل آرا رو با همون مقدار (اشتباه) بازنویسی می‌کنن. جدول زمانی اتفاقات این شکلی میشه:

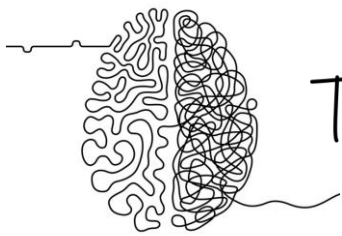
- رای اول میاد و عدد شروع رو ۵۷۶ می‌گیره.
- رای اول عملیات جمع (+۱) رو شروع می‌کنه.
- رای دوم میاد و باز هم عدد شروع رو ۵۷۶ می‌گیره (چون هنوز رای اول تموم نشده).
- رای اول عدد کل رو به ۵۷۷ به‌روزرسانی می‌کنه.
- رای دوم هم عدد کل رو دوباره به ۵۷۷ به‌روزرسانی می‌کنه، به جای ۵۷۸.



The Hacker Mindset

اگر فرض کنیم چیزی که بالا گفتم برات قابل درکه، شاید فکر کنی از دست دادن چندتا رای مثبت برای یه رویداد، اونقدرام مسئله بزرگی نیست. درسته، اما تصور کن همین منطق معیوب، روی یه سیستم مدیریت بازپرداخت پول تو یه پلتفرم تجارت الکترونیک، یا روی یه سیستم انتقال وجه یه بانک آنلاین پیاده‌سازی شده باشه. می‌تونی خسارت احتمالی رو ببینی؟ اگر نه، بذار اینطوری بگم: سال ۲۰۱۴ یه بانک بیت‌کوین به اسم فلکس‌کوین (Flexcoin) بیش از ۴۰۰,۰۰۰ دلار رو به خاطر یه حمله هکری که با سوءاستفاده از Race Condition و دقیقاً با همین تکنیک انجام شد از دست داد. و با تکنولوژی‌های جدید قراردادهای هوشمند (تراکنش‌هایی که روی بلاک‌چین ثبت می‌شن)، دفاع در برابر حملات Race Condition داره روزه‌روز مهم‌تر میشه.

همونطور که می‌بینی، گاهی برای هک یه سیستم حتی نیازی به نوشتن کدهای پیچیده و مخرب نیست. تنها چیزی که لازم داری ارسال یه درخواست HTTP قانونی در زمان مناسب. این به این معنی نیست که کار آسونیه، اما خیلی جالبه حداقل برای من که ببینی سلاح اینجا یه کد مخرب یا یه کامپیوتر آلوده نیست، بلکه خودِ زمانه. ما می‌تونیم زمان رو تبدیل به یه سلاح کنیم.



The Hacker Mindset

شکست دادن ریاضی با زمان

Race Condition تنها باگی نیست که از زمان برای سوءاستفاده از سیستم استفاده می‌کند. چیزای جذاب بیشتری برای کشف کردن وجود دارد. این کد یکی از رایج‌ترین پیاده‌سازی‌هایی که موقع بررسی کد باهاش برخورد می‌کنم:

```
?>php
```

```
if( $_GET[token] == pass ){
```

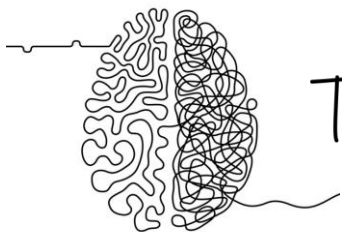
```
//execute program here
```

```
}
```

از خواندن کد بالا نترس. حتی اگر فنی هم نباشی، خیلی ساده‌ست. `$_GET[token]` (که به جورایی یعنی توکن رو بگیر) یعنی داریم مقداری به اسم `token` رو که مستقیماً داخل آدرس URL قرار داده شده، دریافت می‌کنیم. آدرس به چیزی شبیه این میشه:

<https://acme.com?token=something>

با استفاده از زبان برنامه‌نویسی پی‌اچ‌پی، `$_GET[token]` مقدار اون کلید `token` رو بهمون میده، و برنامه این مقدار رو با به رشته ثابت که مستقیماً تو کد تعریف شده مقایسه می‌کند. اگر با هم جور در بیان، برنامه ادامه اجرا رو پیش می‌بره. این روش معمولاً برای اجرای به صفحه وب که قراره خصوصی یا محافظت‌شده باشه، یا اطلاعات



The Hacker Mindset

خصوصی ای رو نشون بده که فقط برای کاربرانی با خبر از مقدار توکن قابل دسترسه، استفاده میشه.

باور کنی یا نه، وقتی من اینو به عنوان یه مشکل امنیتی علامت می‌زنم، حتی برنامه‌نویسای کهنه کار با سال‌ها تجربه هم مشکل رو نمی‌فهمن، و بعضیاشون گله می‌کنن و می‌گن که از یه توکن به لحاظ ریاضی غیرقابل نفوذ استفاده کردن. استدلالشون اینطوریه: ما از یه توکن ۶۴ کاراکتری استفاده می‌کنیم، و صدها سال و میلیاردها تلاش لازمه تا کرک بشه و جواب من اینه: حتماً، ولی کی گفته برای کرک کردنش به این همه تلاش نیاز داریم؟

ما قطعاً اینجا یه مشکل زمانی داریم، و مشکلات بالقوه بدتری هم که هیچ ربطی به حملات Brute Force ندارن. بیا اول مشکل زمان‌بندی رو بررسی کنیم. وقتی زبان PHP دو تا رشته رو مقایسه می‌کنه، این کار رو کاراکتر به کاراکتر انجام میده. یعنی $aa = bb$ همون مقایسه کاراکتر اول شکست می‌خوره چون $a \neq b$ ، اما $cc = cd$ تو کاراکتر دوم شکست می‌خوره، چون $c = c$ ولی $c \neq d$. این خیلی منطقیه، چون چطور دو رشته می‌تونن مساوی باشن وقتی یکی از کاراکترهاشون فرق داره؟ پس مقایسه به محض اینکه به یه کاراکتر متفاوت برسه، شکست می‌خوره. و اینجا لحظه‌ایه که طرز فکر هکری ما وارد عمل میشه: ما می‌تونیم زمان اجرای عملیات رو ارزیابی کنیم تا توکن رو تیکه‌تیکه به دست بیاریم. اگه کاراکتر اشتباه باشه، عملیات زودتر شکست می‌خوره. پس پیدا کردن کاراکتر درست زمان کمتری از ما می‌گیره و می‌تونیم بریم سراغ کاراکتر



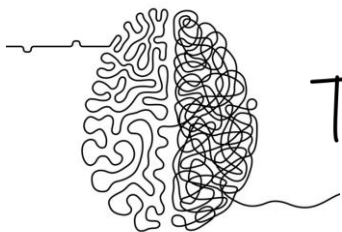
The Hacker Mindset

بعدی. با این تکنیک، می‌تونیم یه رمز عبور رو فقط با چندصد تلاش در عرض چند دقیقه به دست بیاریم، به جای چندین سال.

واقعاً شگفت‌انگیز نیست؟ ما می‌تونیم با استفاده از هیچی جز زمان، یه توکن دسترسی رو هک کنیم. برای محافظت در برابر حملات زمان‌بندی (Timing Attacks)، زبان PHP یه تابع درونی به اسم `hash_equals()` داره تا مقایسه رشته‌ای امن از نظر زمانی انجام بده. خب، اگه از `hash_equals()` استفاده کنیم، کد بالا امن میشه؟ هنوز نه. این فقط امنیت زمانی رو فراهم می‌کنه، اما راه‌های دیگه‌ای هم هست که ممکنه همه‌چیز خراب بشه. واسه همین که تصمیم گرفتم از این تیکه کد برای بحث درمورد امنیت استفاده کنم: یه خط ساده‌ست با کلی راه مختلف برای مشکل درست کردن.

از دست دادن تصویر بزرگ

یادته وقتی راجع به دید تونلی حرف زدیم؟ اینکه مثال بالا رو صرفاً به خاطر حل مشکل زمان، امن بدونیم، یه اشتباه از نوع دید تونلیه. به عنوان یه هکر، تو نیاز داری به تصویر بزرگ نگاه کنی و همیشه تمام بازیگرای حاضر در میدون رو تو ذهنت داشته باشی. تو این مورد، ما یه برنامه PHP داریم که معمولاً توسط یه برنامه دیگه به اسم وب سرور اجرا میشه. وب سرور طراحی شده تا درخواست‌های ورودی رو از یه ماشین دیگه (کلاینت) دریافت کنه، یه کدی رو پردازش کنه و یه پاسخ برگردونه. بیشتر اوقات، وب سرور طوری طراحی شده که درخواست‌های ورودی رو تو یه فایل متنی لاگ (Log)

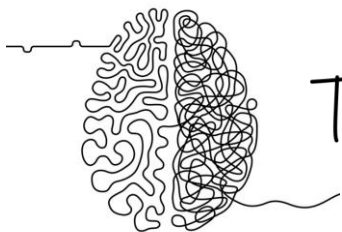


The Hacker Mindset

یا ثبت کنه. بخش‌هایی از درخواست هستن که لاگ می‌شن و بخش‌هایی هم لاگ نمی‌شن. پارامترهای URL جزو چیزایی هستن که لاگ می‌شن.

برگردیم به بحث امنیت. اگه من سوال زیر رو بپرسم: آیا افرادی که تو سازمان شما به لاگ‌های وب سرور دسترسی دارن، باید به اون توکن‌ها هم دسترسی داشته باشن؟ جواب معمولاً نه هست، و این خودش یه مشکل امنیتی. اما مشکل فقط این نیست. صفحات وب معمولاً شامل چیزی هستن که بهشون می‌گیم اسکریپت‌های شخص ثالث. اینا رو مثل برنامه‌هایی در نظر بگیر که داخل برنامه اصلی هستن، اما از سرورهای دیگه دریافت می‌شن. بعضی از نمونه‌های خیلی معروفش Google Analytics و Facebook Pixel هستن. در بعضی از پیکربندی‌های وب سرور (بسته به سیاست‌های CORS)، کل URL شامل پارامترهاش، در اختیار این سرورهای شخص ثالث قرار می‌گیره.

دوباره، اگه سوال زیر رو بپرسم آیا افرادی که به لاگ‌های وب سرور اون شرکت‌های خارجی دسترسی دارن، باید به اون توکن‌ها و در نتیجه به اون صفحات خصوصی دسترسی داشته باشن؟ جواب یه نه بزرگه، و اینجا مشکل امنیتی برای هر کسی، چه فنی چه غیرفنی، کاملاً واضح میشه. عذر می‌خوام اگه مثال‌های بالا زیادی تئوری بودن، اما اگه یه مثال عملی می‌خوای تا تاثیرش رو بفهمی، به مکانیزم بازایی رمز عبور فکر کن. اگه تو صفحه بازایی رمزت یه اسکریپت شخص ثالث داشته باشی و از تنظیمات CORS اشتباه استفاده کنی، هر بار که یه کاربر سعی می‌کنه رمزش رو ریست کنه، یه نفر تو یه



The Hacker Mindset

سازمان دیگه می‌تونه حساب کاربر رو تصاحب کنه، به داده‌های خصوصی دسترسی پیدا کنه، جای کاربر جا بزنه و غیره.

این اتفاق چقدر می‌افته؟ طبق تجربه من، من هر بار که اولین نفری باشم که یه زیرساخت رو بررسی می‌کنم، این جور آسیب‌پذیری‌ها رو پیدا می‌کنم. و این نشون میده که بعضی برنامه‌نویس‌ها برای تفکر انتقادی آموزش ندیدن. این اشکالی نداره؛ خود منم قبلاً این جور اشتباهات رو می‌کردم، تا اینکه تصمیم گرفتم از یه زاویه دیگه به کدم نگاه کنم. واسه همین که باید طرز فکر هکری رو پرورش بدی تا بتونی یه هکر باشی، یه برنامه‌نویس، و همونطور که بعداً تو این کتاب می‌بینیم حتی یه باریستا (کافه‌چی) هم باشی.

این فصلی که خوندی، در ظاهر فنی و تخصصیه، اما در باطن داره یه درس خیلی عمیق‌تر از صرفاً باگ Race Condition یا حملات زمان‌بندی رو بهت یاد میده. این فصل در واقع داره نشونت میده که چطور فرضیات می‌تونن دشمن اصلی امنیت باشن.

بیا با هم مرور کنیم. برنامه‌نویس ارشد اون شرکت جشنواره موسیقی، یه فرض ساده داشت، یه رای مثبت، یه عملیات ساده‌ست، کی ممکنه دو تا رای همزمان بیان؟ اما این فرض، کل سیستم رو آسیب‌پذیر کرد. از اون طرف، تو مثال احراز هویت با توکن، برنامه‌نویس یه فرض دیگه داشت: من یه توکن ریاضی غیرقابل نفوذ ساختم، پس امنم.



The Hacker Mindset

اما باز هم اشتباه کرد، چون به این فکر نکرده بود که چه کسانی دیگه‌ای ممکنه این توکن رو ببینن؟ و آیا نحوه مقایسه‌ش امن هست؟

این یعنی فرضیات ناگفته (Implicit Assumptions) قاتل خاموش امنیت هستن. یه برنامه‌نویس ممکنه فرض کنه که:

- کاربر فقط از مرورگر استفاده می‌کنن (پس می‌شه به validation سمت کلاینت اعتماد کرد).

- لاگ‌های سرور رو فقط آدمای خودی می‌بینن (پس اشکال نداره توکن توی URL باشه).

- عملیات سرور آنی و بدون وقفه انجام میشه (پس Race Condition وجود نداره).

اما یه ذهن هکری دقیقاً روی همین فرضیات ناگفته دست می‌ذاره. هکر نمیدانم بگه کدت باگ داره. میدانم که چیزی که بهش فکر نکردی، چیه؟ و این بزرگترین تفاوتیه. تو این فصل، تو عملاً داری یاد می‌گیری که چطور مثل یه کارآگاه، فرضیات پنهان پشت کدها و سیستم‌ها رو پیدا کنی و به چالش بکشی.

و نهایتاً، بذار به یه نکته جالب دیگه هم اشاره کنم که شاید از لابلای خطوط این فصل بشه برداشت کرد. آسیب‌پذیری‌ها یهو از آسمون نازل نمی‌شن. اونا نتیجه مستقیم



The Hacker Mindset

تصمیمات طراحی هستن. یه تصمیم به ظاهر ساده مثل توکن رو بذاریم تو URL یا اعتبارسنجی رو با یه if ساده انجام بدیم، می‌تونه ماه‌ها بعد به یه فاجعه امنیتی تبدیل بشه. پس امنیت فقط پیدا کردن باگ نیست، امنیت یعنی فهمیدن طرز فکر کسی که سیستم رو ساخته. و این دقیقاً همون چیزیه که تو این فصل تمرینش کردی، حتی اگه خودت متوجهش نشده باشی.

0x05 I'm in Your House

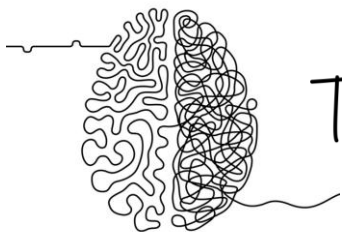
تقریباً تو همه فیلم‌های اکشن این صحنه رو دیدیم، یه نفر دوربین‌های مداربسته رو هک می‌کنه تا یه نفر دیگه رو زیر نظر بگیره. یه روز، دوست‌دخترم آرنیسا ازم پرسید که آیا این کار به همین آسونی که تو فیلم‌ها نشون می‌دن هست یا نه؟ کاری که بعدش کردم، دهنش رو از تعجب باز گذاشت و یه کمیم ترسوندش. لپ‌تاپم رو باز کردم و چندتا دکمه رو فشار دادم، و بعد از پونزده دقیقه داشتیم به تصاویر زنده‌ای نگاه می‌کردیم که از داخل خونه‌های آدمای غریبه می‌ومد. اینا آدمای کاملاً تصادفی بودن، بلکه کسایی بودن که تو شعاع چند کیلومتری خونه خودمون زندگی می‌کردن. چطور همچین چیزی ممکن بود؟ یه جور ترفند تو کار بود؟ این چیزیه که تو این فصل درموردش بحث می‌کنیم.



The Hacker Mindset

من اول کتاب قول دادم که این کتاب معمولی چطور فلان چیز رو هک کنیم نخواهد بود، و پای قولم می‌مونم. چیزی که میبینیم، فرآیند ذهنی‌ایه که می‌تونه به هر کسی اجازه بده مثل یه فیلم سینمایی، دوربین‌ها رو هک کنه. اما اولش، به یه قطره کوچیک دانش قبلی درمورد آدرس‌های IP و اینکه چیزای مختلف چطور به اینترنت وصل می‌شن نیاز داریم. وقتی مرورگرت رو باز می‌کنی و آدرس یه وب‌سایتی مثل www.duckduckgo.com رو تایپ می‌کنی، تو مستقیم به اون وب‌سایت وصل نمیشی. در عوض، مرورگرت از یه سرور DNS سوال می‌کنه که اون آدرس متنی رو به یه آدرس آی‌پی عددی (مثلاً ۱۰۴.۲۱.۴۶.۱۴۹) ترجمه کنه. و فقط بعد از اینکه مرورگر، آی‌پی سایت رو به دست آورد، می‌تونه بهش وصل بشه و شروع به کار کنه. اما آدرس آی‌پی یه وب‌سایت، متعلق به خود وب‌سایت نیست. بلکه متعلق به دستگاهیه که اون رو میزبانی می‌کنه (همون سرور). به زبون ساده‌تر، هر دستگاهی که به اینترنت (یا هر شبکه دیگه‌ای) وصله، یه آدرس آی‌پی داره.

دوربین‌های مداربسته هم معمولاً به یه شبکه خصوصی یا عمومی وصلن تا مردم بتونن از راه دور کنترلشون کنن. به شرکت‌هایی فکر کن که اپلیکیشن موبایل می‌سازن تا خونه‌ت یا سگت رو به صورت زنده کنترل کنی. این اساساً یعنی گوشیت از طریق اینترنت به دوربینت وصل میشه و تصاویر رو بهت نشون میده. برای اکثر حرفه‌ای‌ها، واضحه که اون رابط‌های ارتباطی باید یه جور سیستم احراز هویت داشته باشن تا مطمئن بشن فقط

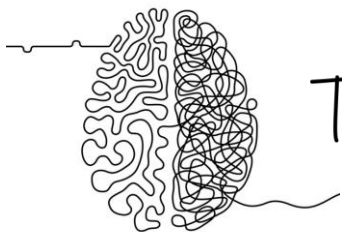


The Hacker Mindset

دستگاه‌ها یا آدم‌های مجاز اجازه دسترسی به دوربین‌ها رو دارن. اما ظاهراً، کلی شرکت تو گذشته فکر می‌کردن اگه کاری کنن دوربین‌ها فقط با یه آدرس آی‌پی خصوصی قابل دسترسی باشه، به قدر کافی امنیت داره. آخرش هم کی می‌تونه یه آدرس آی‌پی رو از بین میلیاردها احتمال پیدا کنه؟

باز هم یه اشتباه بزرگ از نوع دید تونلی. سیستم آدرس‌دهی آی‌پی یه ویژگی خاص داره که برای هکرها خیلی جذابه، قابل پیش‌بینی بودنه. آدرس‌های آی‌پی، حداقل تو نسخه ۴ (IPv4) که تا چند سال پیش استفاده می‌کردیم، می‌تونن از 0.0.0.0 تا 255.255.255.255 باشن. (اخیراً استفاده از یه نسخه جدید به اسم IPv6 رو شروع کردیم، چون داشتن آدرس‌های آی‌پی نسخه ۴ به خاطر تعداد عظیم دستگاه‌های متصل به اینترنت تموم می‌شد.) خب، چه چیزی جلوی هکرها رو می‌گیره که تک‌تک آدرس‌های آی‌پی موجود تو این بازه رو به صورت انبوه اسکن نکنن تا هر جور دستگاه عجیب و غریبی رو پیدا کنن؟ از نظر فنی، هیچی. از نظر قانونی... یه داستان دیگه‌ست. و وقتی می‌گم اسکن کردن، منظورم اینه که سعی کنن مستقیماً به هر آی‌پی در دسترسی دسترسی پیدا کنن و جواب‌هایی که می‌گیرن رو تحلیل کنن تا تو مورد ما، دوربین‌های امنیتی باز و بدون محافظ رو تشخیص بدن.

و این دقیقاً همون ترفند جادویی منه. من داشتم یه دوربین خاص رو هک نمی‌کردم (این کار غیرقانونیه و خیلیم پیچیده‌تره)؛ من فقط داشتم به آدرس‌های آی‌پی دسترسی پیدا



The Hacker Mindset

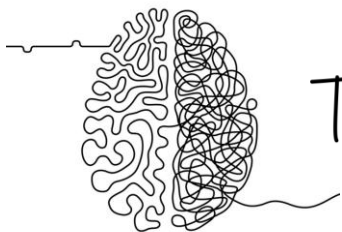
می کردم، پورتهاشون رو اسکن می کردم و جواب هایی که می گرفتم رو بررسی می کردم تا به مدل دوربین پرطرفدار رو پیدا کنم. به همین جوابی نشون دهنده اش بود:

RTSP/1.0 200 OK

Server: *cam RealServer/V1.0**

تو اون زمان، ده ها هزار دوربین باز و بدون محافظ فقط برای اون یک مدل خاص وجود داشت، به عدد باور نکردنی. این دیگه به فیلم سینمایی نیست؛ این زندگی واقعی، جایی که با به کم دانش فنی، تو به پنجره رو به دنیا داری که از بین هزاران دوربین مدار بسته محافظت نشده رد میشه.

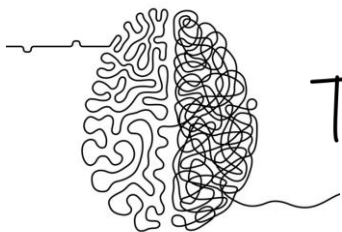
اگه الان داری تو فکری که با همین تکنیک چه چیزای دیگه ای می شه پیدا کرد، داری مثل به هکر فکر می کنی، کارت خوبه. و اگه این مسیر رو بری، چیزای به طرز دیوانه واری جذاب کشف می کنی. پریترا مون الان به اینترنت وصلن، ساعت هامون، دستگاه های قهوه ساز مون، حتی بعضی وقتا عینک هامون... واقعاً فکر می کنی این قضیه بدون عواقب ناخواسته تموم میشه؟



0x06 No More Coffee

حس می‌کنم وقتشه دیگه از IP، PHP و Race Condition حرف نزیم. الان وقتشه در مورد چیرالی حرف بزیم، یکی از جاهای مورد علاقه من روی این کره خاکی عزیزمون. چیرالی یه روستای کوچیک تو جنوب غربی ترکیه‌ست که با کوه‌ها و طبیعت احاطه شده، با یه ساحل سنگی قشنگ، آبی شفاف مثل کریستال، یه فضای آرام و پر از صلح، و کلی هم گربه‌های باحال داره. و انگار که اینا به اندازه کافی جذاب نیست، اگه از کوه‌ها بری بالا می‌رسی به کوه خیمرا و شعله‌های ابدیش، که واقعاً یه جای جادویه. من سال گذشته تقریباً یه ماه رو تو چیرالی گذروندم و از راه دور با لپ‌تاپم کار می‌کردم. این کاریه که مرتب از جاهای مختلف دنیا انجام می‌دم. کافه کار اشتراکی مورد علاقمون یدی کافه بود. به ترکی، یدی یعنی هفت. یه جای ریلکس و رنگارنگ با غذاهای خوشمزه و چندتا عشایر دیجیتال (آدمایی که از راه دور کار می‌کنن) دیگه هم که اونجا کار می‌کردن که بودنشون ضرر که نداره هیچ، گربه‌های بازیگوش و حتی چندتا مرغ هم داشت.

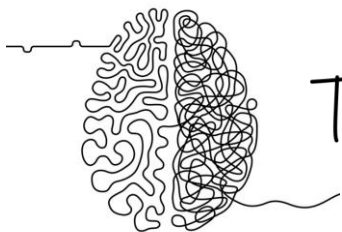
یه روز درست بعد از اینکه نشستیم سر میزمون، صاحب کافه اومد پیشمون، عذرخواهی کرد و بهمون گفت که متأسفانه نمی‌تونن برامون قهوه درست کنن، چون یه خاموشی سراسری کل شهر آنتالیا رو تحت تاثیر قرار داده. ما جواب دادیم: اشکالی نداره و پرسیدیم می‌تونیم بازم بمونیم و کار کنیم. جوابش این بود که البته که می‌تونیم؛ مردم



The Hacker Mindset

ترکیه واقعاً خیلی خوبن. یه ساعت گذشت و شریکم آرنیسا واقعاً شروع کرد به هوس قهوه کردن. واسه همین از صاحب کافه پرسیدیم آیا حداقل می‌تونیم قهوه ترک بگیریم، با علم به این موضوع که برای درست کردنش برق لازم نداریم، فقط یه شعله و یه کپسول گاز لازمه. اونم خوشحال شد که برامون یه قهوه ترک خوشمزه درست کنه و بعد ده دقیقه، با فنجونای بخارکن و خوش‌عطرش برگشت پیشمون. خیلی زود، مردم تقریباً از همه میزهای دیگه هم قهوه ترک سفارش دادن. واسه همین اون شروع کرد برای همه درست کردن.

چرا این داستانو بهت می‌گم؟ چون این یه مثال عالی از تفکر خارج از چارچوب (Out-of-the-box thinking) هست که به یه کافه تو وسط ناکجا اجازه داد بدون برق به کسب و کارش ادامه بده. البته که صاحب کافه می‌تونست خودش این ایده به ذهنش برسه، اما احتمالاً اون انقدر روی این موضوع تمرکز کرده بود که همه (که بیشترشون اروپایی بودن) معمولاً اسپرسو یا کاپوچینو سفارش می‌دادن، که هر دو برق لازم داشتن. اما خوشبختانه براش (و برای همه ما)، ما یه پیشنهاد برنده بهش دادیم. این برای من هک کردنه یه راه دیگه رو انتخاب کنی و بینی چی میشه، از یه خاموشی استفاده کنی تا بفهمی مشتریات قهوه سنتی ترک رو هم دوست دارن، حل کردن یه مشکل به یه روش غیرمعمول و نامتعارف.



The Hacker Mindset

غرفه نمایشگاهی نامرئی

حالا که بحث مشکله، من تو WordCamp نیش تو سال ۲۰۱۹ یه مشکل باحال برام پیش اومد. WordCamp ها کنفرانس‌هایی هستن با میزبانی محلی که همه‌چیز رو درمورد وردپرس، محبوب‌ترین سیستم مدیریت محتوا برای وب‌سایت‌ها، پوشش می‌دن. من به عنوان سخنران تو این رویداد شرکت کردم تا (حدس بزن چی) راجع به امنیت نرم‌افزار حرف بزنم. همچنین یه شرکت که اسپانسر رویداد بود باهاش تماس گرفتم و می‌خواست نرم‌افزار ترجمه‌ش رو تبلیغ کنه. ازم پرسیدن مایلم غرفه نمایشگاهیشون رو مدیریت کنم تا محصولشون رو به شرکت‌کننده‌های WordCamp معرفی کنم. درخواست عجیبی بود چون من مروج نیستم، ولی گفتم قبول، چون همیشه به تجربه‌های جدید مشتاقم.

روز رویداد، قرار بود یه غرفه، بروشور، خودکار، تی‌شرت و کل اون اجناس تبلیغاتی (Swag) که شرکت‌ها تو این رویداد پخش می‌کنن تا توجه مردم رو جلب کنن بهم بدن. اما متأسفانه، به خاطر یه مشکل با پست صربستان، پکیج هیچوقت نرسید. من ناامید شده بودم و به شرکت زنگ زدم که بپرسم حالا که هیچی برای تبلیغات ندارم باید چیکار کنم. اونا فقط جواب دادن، بخاطرش متأسفیم. لطفاً هر کاری از دست برمیاد انجام بده. فقط چندتا غرفه تو رویداد بود، اما همشون پر بودن از گجت‌های هیجان‌انگیز و من هیچی نداشتم. پس بعد از یه کم فکر کردن، چندتا برگه کاغذ برداشتم، به هم

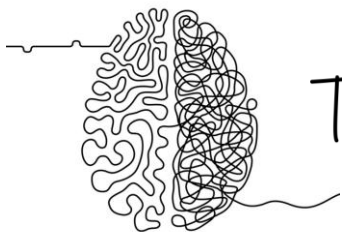


The Hacker Mindset

چسبوندمشون و یه بنر سائز متوسط درست کردم و روش با حروف درشت این عبارت رو نوشتم: ما اجناس تبلیغاتی نداریم، ما تی شرت نداریم، اما نرم افزار ترجمه فوق العاده ای داریم بنر رو گذاشتم روی غرفه خالیم و لپ تاپم رو روی صفحه اصلی سایت نرم افزار باز کردم تا مردم بفهمن می تونم یه دموی زنده از نرم افزار نشون بدم. بعدش بهترین لبخندم رو روی صورتم گذاشتم و منتظر موندم. واکنش ها باورنکردنی بود.

مردم شروع کردن به خوندن بیلبورد دست سازم و لبخند می زدن، با من احساس همدردی می کردن از اینکه چیدمان غرفه چقدر ضعیف بود و حتی از این غرفه نامتعارف عکس می گرفتن. تو عرض چند دقیقه، کلی آدم ایستادن و ازم درمورد نرم افزار سوال کردن. من شروع کردم به ارائه دموهای زنده، که در واقع بهترین راه برای تجربه کردن یه محصول نرم افزاریه.

یه موفقیت بزرگ بود، و این روش خلاقانه من بود برای جبران مواد تبلیغاتی گم شده. این یه مثال دیگه ست از اینکه چطور تفکر جانبی (Lateral Thinking) تو موقعیت های غیرفنی زیادی به کار میاد، و چطور می تونی راه خودت رو برای خروج از یه موقعیت ناخوشایند هک کنی.

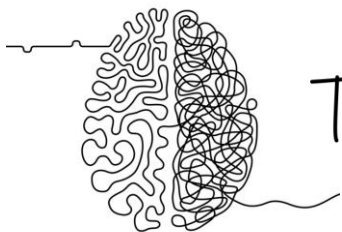


The Hacker Mindset

این فصل رو که می‌خونی، شاید اولش به نظر برسه نویسنده داره یه استراحت خوشایند از مباحث فنی بهت میده. اما زیر پوست این داستان‌های به ظاهر ساده، یه اصل عمیق و حرفه‌ای از دنیای هکینگ جریان داره که اسمش رو می‌ذارم: هنر بازتعریف مسئله (The Art of Problem Reframing).

ببین، تو هر دو داستان این فصل، یه مشکل وجود داره که در نگاه اول، غیرقابل حله. تو داستان اول، مشکل اینه: ما نمی‌تونیم قهوه درست کنیم، چون برق نیست. تو داستان دوم، مشکل اینه: من نمی‌تونم غرفه رو تبلیغ کنم، چون هیچ وسیله‌ای ندارم. اما ببین چطور هر دو مشکل با یه پیچش ذهنی ساده حل می‌شن. تو داستان اول، سوال رو از چطور برق رو برگردونم؟ تغییر می‌دیم به چطور قهوه درست کنم بدون برق؟. تو داستان دوم، از چطور وسایل تبلیغاتی جور کنم؟ می‌رسیم به چطور بدون وسایل تبلیغاتی، توجه جلب کنم؟. این تغییر سوال، دقیقاً همون چیزیه که یه هکر حرفه‌ای انجام میده. تو یه تست نفوذ، وقتی به یه دیوار امنیتی برخورد می‌کنی، آدمای مبتدی می‌پرسن چطور این دیوار رو بشکنم؟. اما هکر با تجربه می‌پرسه: آیا اصلاً نیازه این دیوار رو بشکنم؟ شاید بشه دورش زد. شاید بشه از زیرش رد شد. شاید اصلاً یه در باز یه جای دیگه هست. این یعنی بازتعریف مسئله، و این دقیقاً همون چیزیه که این فصل به صورت غیرمستقیم داره بهت یاد میده.

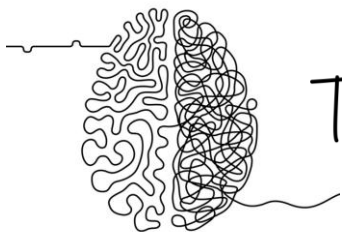
نکته ظریف دیگه‌ای که اینجا هست، قدرت آسیب‌پذیری صادقانه (The Power of Radical Honesty) تو داستان غرفه‌ست. ببین من چیکار کردم: به جای اینکه سعی



The Hacker Mindset

کنم ضعفم رو قایم کنم یا تظاهر کنم همه چیز مرتبه، دقیقاً رفتم و کمبودم رو به بزرگترین نقطه قوتم تبدیل کردم. بنری که نوشتم، عملاً یه اعتراف صادقانه بود: ما هیچی نداریم! و همین صداقت غیرمنتظره بود که توجه‌ها رو جلب کرد. تو دنیای هکینگ هم گاهی بزرگترین قدرتت، پذیرش و استفاده خلاقانه از محدودیت‌هاته. یه هکر خوب می‌دونه که لازم نیست همیشه قوی‌ترین ابزار رو داشته باشه. کافیه چیزایی که داره رو جوری استفاده کنه که کسی تا حالا استفاده نکرده.

پس این فصل رو اینجوری خلاصه می‌کنم: دفعه بعد که به یه مشکل غیرقابل حل برخوردی، قبل از اینکه از خودت بپرسی چطور حلش کنم؟، از خودت بپرس مطمئنم که سوال درستی رو می‌پرسم؟ و بعدش، ببین آیا می‌تونی ضعفت رو به یه نقطه قوت تبدیل کنی. این دو تا مهارت، از هر ابزار فنی‌ای که بلد باشی، برات ارزشمندتر خواهند بود.

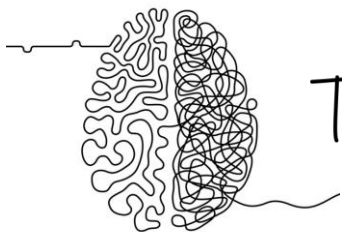


0x07 It's Not About Money

درسته که طرز فکر هکری می‌تونه از موقعیت‌های سخت نجات بده، اما می‌تونه تو دردسر هم بندازت. و البته که من اینو بیشتر از یه بار تجربه کردم.

چند سال پیش، درست مثل اکثر مردم دنیا، تو خونه قرنطینه بودم. کرونا نداشتم، اما داشتم از امارات متحده عربی برمی‌گشتم که اون موقع طبق قانون ایتالیا یه منطقه پرخطر حساب می‌شد (در حال حاضر که دارم این کتاب ترجمه میکنم یعنی بهار ۱۴۰۵، هم یه منطقه پرخطر حساب میشه و امیدوارم هر چه زودتر شروع به شخم زدنش کنم). و برای کسانی که از اون منطقه برمی‌گشتن، ده روز قرنطینه اجباری بود. با کلی وقت آزاد، آخر هر روز یه نیم‌ساعتی رو صرف چک کردن لاگ‌های HTTP خودم می‌کردم. برای خواننده غیرفنی، خوبه که یه توضیح بدم.

وقتی از هر وب‌سایتی بازدید می‌کنی، کامپیوترت (که بهش می‌گیم کلاینت) به سرورهای دیگه‌ای که وب‌سایت‌ها رو میزبانی می‌کنن وصل میشه، بهشون درخواست می‌فرسته و جواب‌هاشون رو تحلیل می‌کنه. سرور اون طرف هم این درخواست‌های HTTP رو دریافت می‌کنه و در واکنش به ورودی‌های کلاینت، یه سری کار انجام میده.



The Hacker Mindset

این تبادل تو لایه کاربرد Application اتفاق می‌افته، که فقط یکی از چندین لایه‌ایه که ماشین‌ها برای ارتباط با هم استفاده می‌کنن. (اگه این مفهوم به نظرت جذاب میاد، با سرچ کردن مدل OSI می‌تونی بیشتر یادش بگیری.) از اونجایی که کنترل کامل روی کلاینت داری (به هر حال این کامپیوتر خودته، نه؟)، می‌تونی کاری کنی که همه درخواست‌ها و جواب‌های HTTP رو لاگ کنه و به صورت فایل‌های متنی ساده ذخیره کنه. و چرا این کار رو می‌کنم؟ چون به نظرم این بهترین راه برای فهمیدن نحوه کار یه نرم‌افزار تحت وبه از بیرون، بدون اینکه هیچ دانش قبلی دربارش داشته باشی (همون روش دانش صفر) و انجام مرتب این کار، یه راه عالییه برای پرورش چشم برنامه‌نویسی و یاد گرفتن مهارت‌های جدید با دیدن اینکه بقیه نرم‌افزارها چطور کار می‌کنن.

وقتی تو قرنطینه بودم، از یه اپلیکیشن موبایل خرید مواد غذایی با تحویل درب خونه خرید می‌کردم. یه روز تو درخواست‌های HTTP این اپ متوجه یه چیز مشکوک شدم. اینجا همون جاییه که طرز فکر هکری تو رو به دردسر می‌ندازه. من به این شک افتادم که داده‌های خودم (به عنوان مشتری) درست محافظت نشده و (به عنوان یه هکر) ممکنه بتونم به داده‌های همه مشتریای دیگه هم دسترسی داشته باشم. به همه شون. این اپ شامل آدرس خونه، شماره تلفن، آدرس ایمیل، رمزهای عبور رمزنگاری‌شده، سفارشات و شماره‌های کارت وفاداری بود. از همه مهمتر، اپ از مردم می‌پرسید که کرونا دارن یا نه تا پرسنل تحویل بتونن احتیاط‌های لازم رو انجام بدن و این اطلاعات تو بخش

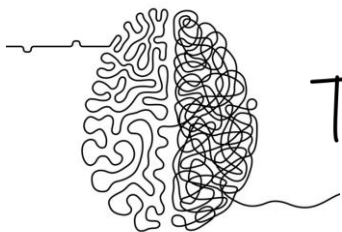


The Hacker Mindset

یادداشت‌های سفارش ذخیره شده بود که اونم قابل دسترسی بود. بدتر از همه اینکه این فروشگاه‌های زنجیره‌ای خیلی بزرگ بود، با شعبه‌هایی در سراسر جنوب ایتالیا و چندصد هزار نفری که تو این اپ ثبت‌نام کرده بودن.

وسوسه اینکه بینم واقعاً می‌تونم به داده‌های همه دسترسی داشته باشم خیلی قوی بود و نمی‌تونستم در برابرش مقاومت کنم، اما کاملاً از این حقیقت آگاه بودم که اگه سعی می‌کردم به داده‌های مردم دیگه دست بزنم، طبق قانون ایتالیا به جرم جدی مرتکب شده بودم که مجازاتش جریمه‌های سنگین و چندین سال زندان بود. من درست جلوی یکی از کلاسیک‌ترین پارادوکس‌های هکری بودم، از یه طرف می‌دونستم کار اخلاقی اینه که آسیب‌پذیری امنیتی رو تایید کنم، به صورت خصوصی به شرکت اطلاع بدم و بذارم درستش کنن. از طرف دیگه، این یه ریسک بزرگ بود چون ممکن بود شرکت واکنش خوبی نشون نده و حتی علیه من شکایت قانونی کنه. واسه همین کار امن (و خودخواهانه) این بود که چیزی که پیدا کرده بودم رو نادیده بگیرم و به زندگیم ادامه بدم.

تصمیم گرفتم شجاع باشم و کار درست رو انجام بدم، چون هر ریسکی که داشت، من نمی‌تونستم بذارم داده‌های تقریباً نیم میلیون آدم بالقوه افشا بشه. به عنوان قدم اول، یه حساب دیگه تو اپ با یه آدرس ایمیل متفاوت ساختم و سعی کردم به داده‌های خودم دسترسی پیدا کنم که موفقیت‌آمیز بود. پس دیگه مطمئن شدم که می‌تونم به هر حساب کاربری روی اپ دسترسی داشته باشم. بعدش، یه تحقیق کردم تا مناسب‌ترین آدرس‌های

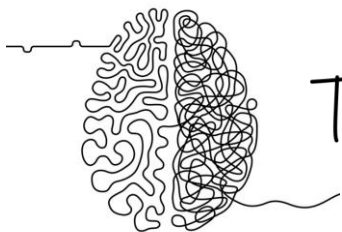


The Hacker Mindset

ایمیل شرکت برای گزارش این موضوع رو پیدا کنم. نهایتاً، یه گزارش آسیب‌پذیری حرفه‌ای نوشتم که شامل یه ویدیوی POC بود و توضیح می‌داد چطور تونستم سیستم رو هک کنم و به همه داده‌ها دسترسی پیدا کنم.

نیم‌ساعت بعد، تلفنی با رئیس امنیتشون صحبت می‌کردم. خیلی مهربون و قدردان بود، ازم بخاطر روش حرفه‌ایم تشکر کرد و بهم اطمینان داد که فوراً آسیب‌پذیری رو درست می‌کنن و اپ رو ایمن می‌کنن، که همین کار رو هم کردن. یه هفته بعد، یه ایمیل پیگیری از طرف یه نماینده شرکت دریافت کردم که پرسیده بود می‌تونیم حضوری ملاقات کنیم؟ منم گفتم باشه. باید اعتراف کنم که یه کم به این ملاقات مشکوک بودم. تلفنی گفته بودن فقط می‌خوان منو بهتر بشناسن و ببینن می‌تونیم برای بهبود امنیتشون باهم همکاری کنیم. اما آدرس ملاقات رو نه تو دفتر مرکزی شرکت، بلکه تو یکی از فروشگاه‌های فروشگاه زنجیره‌ای بهم دادن و این به نظرم عجیب بود.

تصمیم گرفتم تنها نرم جلسه و شریکم آرنیسا پیشنهاد داد باهام بیاد. اون دیدار کاملاً سورئال بود. یه ملاقات ده‌دقیقه‌ای سرپایی بیرون فروشگاه بود که تو اون، یه پاکت شامل سه تا کارت هدیه صد یورویی بهم دادن که نشون بدن شرکت بابت گزارشم چقدر قدردونه. اونا همچنین یه عالمه داستان مسخره تعریف کردن از اینکه فکر می‌کردن یه مجرم سایبری هویت منو دزدیده و اپ رو هک کرده تا ازشون باج بگیره، یا اینکه من با



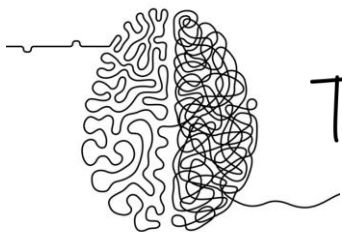
The Hacker Mindset

پلیس کار می‌کنم و از این سناریوهای سینمایی. آخر جلسه هم بهم گفتن می‌تونم رزومه‌م رو بفرستم و خارج از نوبت بررسی میشه، ولی من مودبانه رد کردم.

تو راه برگشت خونه، ناامید شده بودم. آسیب‌پذیری‌ای که من گزارش کردم می‌تونست باعث میلیون‌ها دلار خسارت مالی برای شرکت به خاطر نقض قوانین GDPR بشه، می‌تونست ازش برای باج‌گیری استفاده بشه، همونطور که خودشون هم خوب تصور کرده بودن، و از همه مهمتر، می‌تونست خسارت زیادی به اعتبارشون بزنه اگه مشتریاشون از نشت داده‌ها با خبر می‌شدن. من از دست همه اینا نجاتشون دادم و اونا حتی منو تو یه دفتر با یه صندلی و یه قهوه خوب پذیرایی نکردن.

نظرم رو با آرنیسا درمیان گذاشتم و جوابش چشمامو باز کرد. تو یه هکری گفت، شرکت‌ها از هکرها تو دفترشون با یه قهوه خوب پذیرایی نمی‌کنن. با خودم فکر کردم شاید حق با تو باشه، اما با این حال، این منصفانه نیست.

پ.ن: هنوزم یکی از اون کارت‌های هدیه روی میزمه، برای اینکه یادم بمونه کاری که می‌کنم رو برای پول نمی‌کنم.



0x08 Cybercriminals

ارائه یه تعریف سراسر برای کلمه هکینگ، به نظر من کار آسونی نیست. به طور کلی، هر تعریفی یه جوریه که دور یه مفهوم پرچین می کشه و محدودش می کنه و ما داریم یاد می گیریم که هکینگ دقیقاً برعکس اینه: فراتر رفتن از تعاریف، فراتر رفتن از چیزایی که می دونیم. اما اگه با یه ذهنیت خرابکارانه از اینکه هکر چیه اومدی این کتاب رو بخونی، تعجب نمی کنم.

بیشتر اوقات، هکرها با اخبار مرتبط با فعالیت های غیرقانونی تو تیتراژها ظاهر می شن و احتمالاً این به کلمه هکر بار معنایی منفی ش رو داده. با این حال، هکینگ همیشه هم منفی دیده نمیشه، و من حس می کنم باید روشن کنیم که هکینگ واقعاً یعنی چی، و کجا این کلمه بد به کار می ره، تا بتونیم بهتر طرز فکر هکری رو به عنوان یه ابزار ببینیم و نه یه اسلحه.

من این کتاب رو تو فوریه ۲۰۲۳ می نوشتم، وقتی که دور و بر مراکش، یه کشور مرموز و الهام بخش، سفر می کردم. وقتی اونجا بودم، یه وقتایی روزنامه های ایتالیایی رو چک می کردم، عمدتاً به خاطر اینکه خانواده و خیلی از دوستان اونجا زندگی می کنن، و این خبر چشمم رو گرفت:

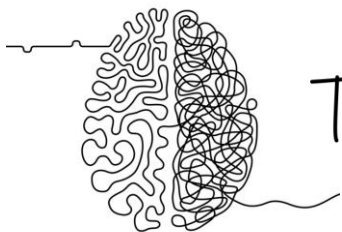


The Hacker Mindset

هکرهای طرفدار روسیه در واکنش به سفر نخست‌وزیر به کی‌یف به ایتالیا حمله کردن. تیرهایی مثل این در طول جنگ روسیه و اوکراین زیاد بودن، و بیشتر اوقات مقاله‌ها به حملات DoS/DDoS اشاره می‌کردن. البته من نمی‌دونم کی پشت اون حملات بوده، روزنامه‌نگارا هم همینطور. اما به اندازه کافی راحتم که بگم اگه بحث حملات DDoS باشه، اون حملات قطعاً از طرف هکرها نیستن.

حمله DoS به تکنیک بیست‌سال‌ست که شامل سرازیر کردن حجم عظیمی از ترافیک به سمت سرور قربانی میشه تا اونو از کار بندازه، بشکونتش، یا حداقل به شدت کندش کنه. هدف نهایی، ایجاد اختلال تو سرویس دهیه. این روزا، این حمله دیگه اونقدر تهدید بزرگیم حساب نمیشه، یعنی اکثر شرکت‌های جدی به تکنولوژی دسترسی دارن که بدون هیچ تلاش خاصی این نوع حملات رو خنثی کنن. خلاصه اینکه اگه واقعاً بخوای به شرکت یا دولت رو آزار بدی، از DDoS استفاده نمی‌کنی. چون حتی اگه حمله موفق بشه، فوراً تو عرض چند دقیقه یا در بدترین حالت چند ساعت شناسایی و خنثی میشه. این کار به هیچ وجه شبیه کار یه هکر به نظر نمیاد.

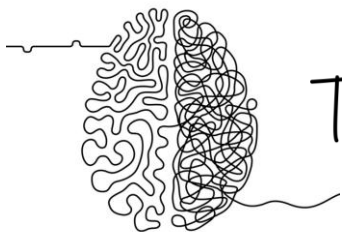
اشتباه برداشت نکن، حملات DoS/DDoS سال‌ها پیش کلی خسارت زدن. کسی که اول بار اختراعش کرد احتمالاً یه هکر بوده، و هر دفعه که یه نفر با یه attack vector جدید (یه راه جدید و بهتر برای انجام حمله) میاد بیرون، این یه هک ناب محسوب میشه و به یه مغز قدرتمند نیاز داره. اما این معنی‌اش این نیست که هر بار یه حمله DoS انجام



The Hacker Mindset

میشه، پشتش هکرها هستن. درست مثل اینکه هر بار یه گلوله شلیک میشه، یه مهندس مکانیک ماشه رو نمی کشه.

رسانه‌های جمعی معمولاً تقصیر هر حمله‌ای که از مسیر دیجیتال انجام میشه رو می‌ندازن گردن هکرها (احتمالاً فقط برای اینکه چندتا کلیک یا بازدید بیشتر بگیرن)، اما این کار آسیب زیادی به این دسته می‌زنه؛ دسته‌ای که در واقعیت شامل آدم‌های بیشماری میشه که می‌خوان از مهارتشون برای انجام کار خوب استفاده کنن، درست مثل کاری که من با اون فروشگاه زنجیره‌ای کردم. اگه کسی واقعاً هکرها رو برای نابود کردن عملیات یه نفر دیگه به کار بگیره، هکرها احتمالاً تو سکوت و بدون اینکه شناسایی بشن به شبکه‌شون نفوذ می‌کنن، همه فایل‌هاشون رو رمزنگاری می‌کنن و همه چیز رو برای همیشه غیرقابل استفاده و غیرقابل بازیابی می‌کنن. یا حتی تاثیر گذارترش اینه که تو شبکه بمونن، فقط جاسوسی کنن و اطلاعات جمع کنن تا حرکات دشمن رو پیش‌بینی کنن.



The Hacker Mindset

هکری که دنیا رو نجات داد

سال ۲۰۱۷، دنیا با یه خطر واقعی به اسم بدافزار وانا کرای (WannaCry) روبرو بود. این ویروس، درست همونطور که تو پاراگراف بالا توضیح دادم، تا جایی که می‌تونست ماشین‌ها رو آلوده می‌کرد، همه داده‌هاشون رو رمزنگاری می‌کرد و بعد یه پیغام نشون می‌داد که توش مجرمان سایبری در ازای دریافت کلید برای رمزگشایی فایل‌ها و گرفتن داده‌های باارزشت، درخواست باج می‌کردن. این مدل عملیاتی، اسم این نوع بدافزار رو گذاشته باج‌افزار (Ransomware).

این اولین باری نبود که یه تهدید مثل اون می‌دیدیم، اما WannaCry فرق داشت. دلیل ساده‌ش این بود که از یه آسیب‌پذیری گسترده و پچ نشده ویندوز استفاده می‌کرد و می‌تونست با سرعت نور پخش بشه. تو عرض چند روز، بیمارستان‌هایی رو دیدیم که به داده‌های بیماران دسترسی نداشتن، ایستگاه‌های پلیس قفل شده بودن، پمپ بنزین‌ها تعطیل شده بودن و ماشین‌ها تو بیش از ۱۵۰ کشور آلوده شده بودن. دنیا کم‌کم داشت اینو به عنوان یه تهدید جهانی می‌شناخت، مردم نگران شدن و سرتیتر همه خبرا شده بود. متخصصای امنیت تو سراسر دنیا بحث می‌کردن چطور میشه متوقفش کرد، و جواب از طرف یه هکر بیست و دو ساله رسید: مارکوس هاجینز. آره، یه نفر به تنهایی یه تهدید جهانی رو متوقف کرد. کاری که اون کرد، احتمالاً همون کاری بود که بقیه هم می‌کردن، مهندسی معکوس بدافزار. یعنی سعی کرد کد باینری ویروس (همون صفر و



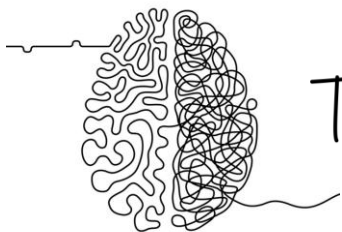
The Hacker Mindset

یک‌ها) رو به کد قابل فهم برای انسان برگردونه. مهندسی معکوس بدافزار کار آسونی نیست، اما برای مارکوس احتمالاً اولین بار نبود. در واقع، اون تونست معجزه رو رقم بزنه و یه Kill Switch که مستقیماً تو خود بدافزار کد شده بود رو پیدا کنه. Kill Switch یه رویه اضطراریه که می‌تونه یه برنامه یا دستگاه رو از کار بندازه، و WannaCry به سادگی چک کردن وجود یه وب‌سایت بود: اگه اون دامنه وجود نداشت، ویروس به آلوده کردن ادامه می‌داد. برعکس، اگه وجود داشت، متوقف می‌شد اسم دامنه هم مستقیماً تو کد بدافزار نوشته شده بود:

iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com

یه دامنه فوق‌العاده پیچیده که مطمئن بشن هیچ کس تصادفی ثبتش نمی‌کنه. تنها کاری که هاکینز باید می‌کرد این بود که این دامنه رو ثبت کنه، و این کار اجرای ویروس رو روی میلیون‌ها و میلیون‌ها ماشین متوقف کرد و به دنیا زمان داد تا سیستم‌های آسیب‌پذیر رو وصله کنن و برای تهدیدهای مشابه آینده آماده بشن، که البته این تهدیدها او مدن.

چند ماه بعد، قهرمان داستان، مارکوس هاکینز، تو ایالات متحده به اتهام کمک به تولید بدافزارهای دیگه، سال‌ها قبل از WannaCry، دستگیر شد. مارکوس یه هکره، معلومه، و ظاهراً تو زندگیش کارهای مجرمانه‌ای هم انجام داده، مثل خیلی از ما. اما هکر و (مجرمان) سایبری کلمات قابل جایگزینی نیستن، و فهمیدنش خیلی مهمه. هر وقت از قدرت مغزت استفاده می‌کنی تا یه کاری رو به روشی هوشمندانه‌تر انجام بدی، و به نتایج



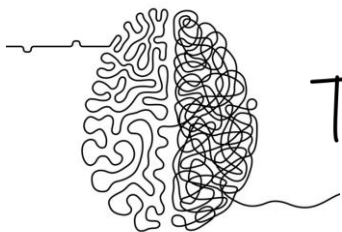
The Hacker Mindset

استثنایی به روشی بررسی که هیچ کس قبلاً بهش نرسیده، تو داری هک می کنی. اینکه می خواهی از طرز فکر هکریت برای کار خوب استفاده کنی یا بد، خب... این دیگه به خودت بستگی داره.

0x09 CVE-2022-0482

من مته مارکوس دنیا رو نجات ندادم، ولی منم به یه چیز خطرناک برخوردم، و با وجود تمام تلاشم، اون تهدید هنوزم کامل از بین نرفته.

هنوز دوران کرونا بود، دقیقاً همون دوره ای که همه دنبال واکسن بودن، به این امید که به زندگی عادی برگردن. تو ایتالیا، دولت تصمیم گرفت اجازه بده داروخونه های خصوصی هم واکسن تزریق کنن تا فرآیند سریع تر بشه. نتیجه اش این بود که تلفن داروخونه ها برای گرفتن وقت ملاقات داغ شده بود. یکی از مشتریام و یه دوست عزیز به من زنگ زد و پرسید می تونم یه سیستم مدیریت وقت ملاقات براشون درست کنم تا مردم رو به یه پلتفرم آنلاین هدایت کنه و فرآیند تعیین وقت، بررسی ظرفیت و بقیه چیزا رو خود کار کنه. کار خیلی جالبی بود که با خوشحالی قبول می کردم، اما یه محدودیت وجود داشت: باید سریع عمل می کردم. شرایط دیگه قابل تحمل نبود و اونا سیستم رو تو سه هفته لازم داشتن. با خودم فکر کردم: سه هفته؟ این دیوونگیه اما باید یه راه حل پیدا می کردم.



The Hacker Mindset

البته که نمی‌تونستم از صفر و تو اون مدت کم، کل سیستم رو کدنویسی کنم. برای همین شروع کردم به تحقیق برای کتابخونه‌ها یا ابزارهایی که می‌تونستن یه سیستم نیمه‌کاره بهم بدن تا بتونم نهاییش کنم و برای نیاز مشتری آماده‌ش کنم. بعد از یه کم گشتن تو گوگل، به این کتابخونه خوب PHP برخورددم به نام EasyAppointments. به نظر می‌رسید سبک و تمیز باشه، دقیقاً مناسب نیاز ما. Open Source بود و کلی شرکت و حتی دولت‌ها ازش برای مدیریت وقت‌های ملاقات آنلاین از هر نوعی استفاده می‌کردن. این خیلی دلگرم‌کننده بود. به مشتری گفتیم می‌تونیم ازش استفاده کنیم تا کل فرآیند رو سریع‌تر پیش ببریم، و اونا موافقت کردن. پس من شروع به کار روش کردم. به‌خصوص برای خواننده‌های غیرفنی، خوبه اشاره کنم که تو چرخه توسعه نرم‌افزار امروزی، تکیه کردن به کتابخونه‌های شخص ثالث برای پیاده‌سازی یه پروژه، یه کار کاملاً رایجه. وقتی این کار رو می‌کنیم، معمولاً کتابخونه‌های خارجی رو ایمن در نظر می‌گیریم... تا اینکه یه مشکلی توش کشف بشه. بعدش (بعضی وقتا) به روزرسانیشون می‌کنیم. مثلاً اگه بخوای یه وبلاگ بسازی، احتمالاً از وردپرس استفاده می‌کنی و اونو ایمن فرض می‌کنی. درمورد Magento برای ساخت سایت فروشگاهی هم همینطوره. اما تو این مورد خاص، می‌دونستم که سیستم قراره شامل هزاران داده حساس باشه. برای همین تصمیم گرفتم حداقل یه بررسی سریع از EasyAppointments انجام بدم. وقت برای اینکه کامل بررسیش کنم خیلی کم بود. واسه همین از گزینه هک‌ریم استفاده



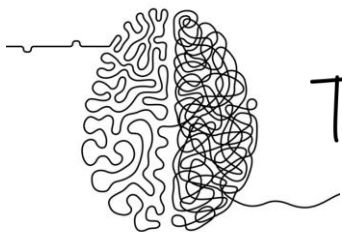
The Hacker Mindset

کردم و قسمت‌هایی رو چک کردم که از نظر تئوری بیشتر احتمال خطا داشتن. فایل‌ها و ساختار پوشه‌ها رو بررسی کردم، و یهو چشمم به فایلی به اسم Backend_api.php افتاد چون وقتی بحث API پیش میاد، معمولاً داده‌ها بین سیستم‌ها در حال جابجایی هستن، که یه زمین حاصلخیز برای آسیب‌پذیری‌هاست.

خوندن صد خط اول کد کافی بود تا بفهمم یه جای کار به طرز خطرناکی می‌لنگه: جواب‌هایی که شامل داده‌های کاربر بود، قبل از بررسی مجوزهای دسترسی ساخته می‌شدن. با دنبال کردن همین مسیر، تونستم سیستم رو هک کنم و ثابت کنم که هر کاربری، فقط با یه درخواست تحت وب، می‌تونه به همه داده‌های موجود تو برنامه دسترسی پیدا کنه. و از همه مهمتر، همه برنامه‌های روی اینترنت که روی اون فریم‌ورک ساخته شده بودن، در برابر همین حمله آسیب‌پذیر بودن.

حالا اگه داری فکر می‌کنی چرا داده‌های کاربران براشون اینقدر مطلوبه، اینو در نظر بگیر که خرابکارا تقریباً همیشه دنبال پولن، و تو دنیای مدرن، داده = پول وقتی یه مجرم صاحب یه دیتابیس پر از اطلاعات هویتی شخصی بشه، می‌تونه کارای زیر رو انجام بده:

- از شرکتی که نتونسته از داده‌ها محافظت کنه، باج‌گیری کنه.
- حملات Credential Stuffing انجام بده و به وب‌سایت‌ها و داده‌های بیشتری دسترسی پیدا کنه.



The Hacker Mindset

- با اسم آدمایی که داده‌هاشون تو دیتابیس دزدیده شده بوده، هویتشون رو جعل کنه.

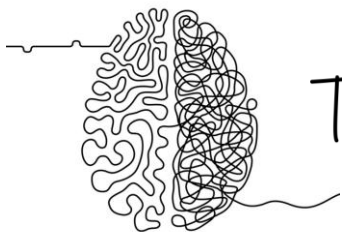
- یا اینکه داده‌ها رو به بازار سیاه بفروشه و راحت پول دریاره.

به همین دلیل، ما قوانین متعددی تو سراسر دنیا داریم که از داده‌های مردم محافظت می‌کنن و نحوه برخورد شرکت‌ها باهاش رو تنظیم می‌کنن. اما با توجه به اینکه چقدر برای آدم‌های ماهر آسونه که این تدابیر رو دور بزنن و به داده‌های نو و تازه دسترسی پیدا کنن، این اقدامات چندان موثر واقع نمیشن.

از اونجایی که می‌دونستم با یه آسیب‌پذیری با شدت بالا روبرو هستم، تصمیم گرفتم فوراً با استفاده از همه کانال‌های موجود گزارشش بدم. خوشبختانه، نویسنده اون کتابخونه خیلی پاسخگو بود و ما با هم همکاری کردیم تا کد رو ایمن کنیم. به این آسیب‌پذیری یه شماره CVE اختصاص داده شد CVE-2022-0482 و به پایگاه داده موسسه ملی امنیت (National Institute of Security Database) اضافه شد. این یکی از رویاهام بود که به حقیقت پیوست:

<https://nvd.nist.gov/vuln/detail/CVE-2022-0482>

اما این داستان پایان خوشی نداره. بله، من یه آسیب‌پذیری خطرناک پیدا کردم و نویسنده هم به موقع درستش کرد. حتی یه اسکریپت منتشر کرد تا بشه سیستم‌ها رو به راحتی وصله کرد. اما این معنی‌اش این نیست که داده‌های مردم امن شده. متأسفانه، این کتابخونه



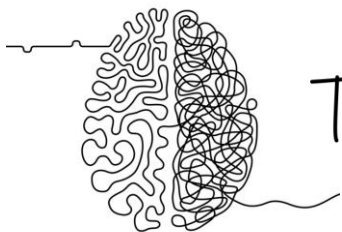
The Hacker Mindset

تو هزاران سیستم استفاده میشه و بیشتر اوقات این سیستم‌ها کتابخونه‌های شخص ثالثشون رو به‌روز نگه نمی‌دارن. در عوض، نرم‌افزارهای رها شده یا آن‌هایی که مرتب به‌روزرسانی نمی‌شن، یکی از بزرگترین تهدیدها تو مقیاس جهانی هستن. این دقیقاً همون دلیلی بود که بدافزار WannaCry (که تو فصل قبل دیدیم) تونست پخش بشه.

امروز، درست تو همین لحظه‌ای که دارم این فصل رو می‌نویسم، یه کم تحقیق کردم و دنبال اهداف آسیب‌پذیر نسبت به CVE-2022-0482 گشتم... هزارتا پیدا کردم. بعضیاشون متعلق به سازمان‌های دولتی ایتالیا هستن، و من حتی به CSIRT ملی (تیم واکنش به حوادث امنیت سایبری) ایمیل زدم، اما تنها چیزی که گرفتم یه کد درخواست ثبت شده بود: UN86IKSK. حالا چی میشه؟ زمان همه‌چیزو نشون میده.

0x0a You Snitch

اولین‌باری که برای لایسنس فتوشاپ پول دادم، بیست سالم بود و ۱۰۷۵ یورو خرج کردم. اون موقع برام یه پول وحشتناک زیاد بود. اما می‌دونستم که پول دادن برای نرم‌افزار کار درستی، و تازه شروع کرده بودم به عنوان یه طراح گرافیک یه پولی در بیارم. واسه همین تصمیم گرفتم روی ابزار اصلی کارم سرمایه‌گذاری کنم یعنی فتوشاپ. قبل از اون روز، از یه نسخه کرک شده (همون دزدی البته تو ایران این چیز عادیه) فتوشاپ استفاده می‌کردم، درست مثل تک‌تک آدمای دیگه‌ای که می‌شناختم. راستش،



The Hacker Mindset

کسی رو نمی‌شناختم که پولش رو بده. دلش به نظر من این بود که اون موقعها برنامه‌های کامپیوتری هم زیادی گرون بودن، هم زیادی راحت کرک می‌شدن.

این روزا، کامپیوتر بدون دسترسی به اینترنت تقریباً به درد نخور حساب میشه. اما یه روزگاری بود که هر ماشینی به این شبکه بزرگ وصل نبود و خیلیا دسترسشون خیلی کم یا حتی صفر بود. به همین دلیل، شرکت‌های نرم‌افزاری یه مکانیزم اعتبارسنجی لایسنس داشتن که درست تو خود نرم‌افزار تعبیه شده بود. وقتی یه برنامه رو نصب می‌کردی، اول کار ازت می‌خواست یه لایسنس وارد کنی، و یه منطقی تو برنامه بود که تصمیم می‌گرفت لایسنس معتبره یا نه. بذار با یه مثال اینو کاملاً روشن کنیم: یه منطق اعتبارسنجی تئوری می‌تونست این باشه که مجموع ارقام لایسنس باید یه عدد زوج بین ۶۹ و ۷۵ باشه. تو این صورت، این لایسنس‌ها معتبر بودن:

• 6543758268659 (مجموع ارقام = ۷۴)

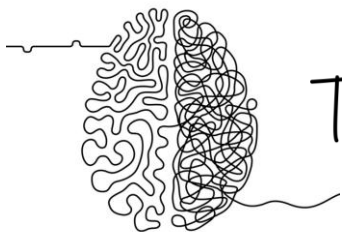
• 121316867658765 (مجموع ارقام = ۷۲)

• 89043589043854 (مجموع ارقام = ۷۰)

اما اینا نه:

• 6543568295534 (مجموع ارقام = ۶۵)

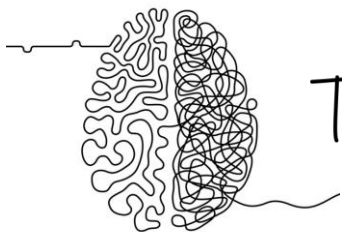
• 897987489372 (مجموع ارقام = ۸۱)



The Hacker Mindset

البته همیشه به این سادگی نبود، چون شرکت‌های نرم‌افزاری شروع کردن به ساختن الگوریتم‌های پیچیده‌تر و پیچیده‌تر تا کرک محصولشون سخت‌تر بشه. اما تو روزهای اول، 111-11111111 یه کلید لایسنس معتبر برای ویندوز ۹۵ بود. دلیلش این بود که برنامه برای سه رقم اول، هر ترکیبی رو قبول می‌کرد (به جز یه لیست سیاه کوچیک که تو کدش بود)، و هر عددی که بر ۷ بخش‌پذیر بود هم به عنوان بخش دوم معتبر بود از اونجایی که این منطق داخل خود برنامه بود، همیشه میشد مهندسی معکوسش کرد، الگو رو پیدا کرد و کلیدهای لایسنس معتبر تولید کرد. حتی نرم‌افزارهایی داشتیم که فقط برای هدف کرک کردن لایسنس وجود داشتن، بهشون می‌گفتن کی‌جن (Keygen). هر اسکریپت‌کیدی (یه آدم آماتور با دانش کم) می‌تونست این کار رو بکنه و تو دوران قبل از اینترنت، کار حسابی پرتर्फداری بود.

یه روز، یهویی، این ترفند دیگه جواب نداد، حداقل برای کپی فتوشاپ من. اولش نمی‌تونستم دلیلش رو بفهمم، اما خیلی طول نکشید که بفهمم چه خبره. همه‌چیز بعد از یه آپدیت فتوشاپ شروع شد، آپدیتی که بعدش اعتبارسنجی لایسنس برنامه دیگه کاملاً محلی نبود، بلکه برای کامل کردن اعتبارسنجی، به یه سرور راه دور وصل می‌شد. این شروع مدیریت لایسنس ابری بود، همون چیزی که این روزا اکثر شرکت‌ها استفاده می‌کنن. البته آسون‌ترین راه حل این بود که یه لایسنس قانونی بخرم. اما اولش تصمیم گرفتم ببینم می‌تونم این مدل اعتبارسنجی جدید رو شکست بدم یا نه.

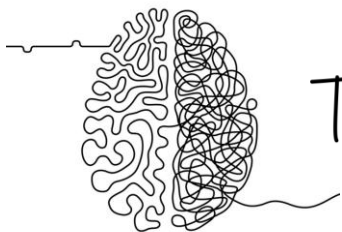


The Hacker Mindset

من هنوز هیچ تجربه برنامه‌نویسی نداشتم، و دانش خاصی هم از نحوه کار کامپیوتر نداشتم. اما تو همون معلومات محدودم، مفهوم فایروال وجود داشت. فایروال‌ها برنامه‌های کامپیوتری هستن که تصمیم می‌گیرن کدوم ترافیک شبکه اجازه عبور داره و کدوم ترافیک رو باید متوقف کرد. اونا سیستم‌های دفاعی خیلی قدرتمند و موثری هستن که هنوزم تو شکل‌های مختلف به طور گسترده استفاده می‌شن.

با دونستن وجود فایروال‌ها، با خودم فکر کردم اگه بشه جلوی یه ارتباط خارجی رو برای رسیدن به یه ماشین یا سرور گرفت، پس باید راهی باشه که برعکسش رو هم انجام داد یعنی جلوی یه برنامه داخلی رو برای وصل شدن به شبکه خارجی گرفت. این دقیقاً کاری بود که فتوشاپ من می‌کرد تا خبرچینی کنه که لایسنس من نامعتبره.

به گشتن ادامه دادم تا اینکه به این نرم‌افزار به اسم Little Snitch برخوردم. این برنامه خودش رو به عنوان برنامه‌ای معرفی می‌کرد که طراحی شده تا ارتباطات مخفی‌ای که برنامه‌های کامپیوتری تونن به اینترنت برقرار کنن رو کشف کنه، به صاحب سیستم اجازه بده بلاکشون کنه و یه سری قانون بسازه تا تو آینده هم بلاک بمونن. این دقیقاً همون چیزی بود که لازم داشتم و اونقدر خوب و عالی کار کرد که حتی فکر کردم برای همین هدف خاص ساخته شده. امروزه هم این برنامه هنوز وجود داره و هنوزم به دردم می‌خوره، مخصوصاً تو دورانی که حریم خصوصی یه دغدغه بزرگه. برای اینکه بدونی



The Hacker Mindset

کامپیوترت به چه سرورایی وصل میشه و به طور کلی ترافیک شبکه رو پایش کنی، خیلی کاربردی.

ماموریت انجام شد. من هنوز می‌تونستم از نسخه کرک‌شده فتوشاپ استفاده کنم، و از همه مهمتر، فهمیده بودم چطور جلوی کامپیوترم رو بگیرم که بدون اطلاع من به هیچ میزبان راه دوری وصل نشه. من کنترل رو در دست داشتم.

البته که دزدی نرم‌افزاری کار بدیه و استفاده از نرم‌افزار کرک‌شده چیزیه که ازش پشیمونم، هرچند به محض اینکه پول خرید برنامه‌های گرونم رو داشتم، این کار رو متوقف کردم. در عین حال، باید اعتراف کنم که دزدی نرم‌افزاری تو خیلی از صنایع، همش هم بد نبود، چون شرکت‌ها رو مجبور کرد قیمت‌هاشون رو پایین بیارن و محصولا‌تشون رو برای آدمای بیشتری قابل خرید کنن. امروز، فتوشاپ فقط ماهی ۱۹ یورو قیمت داره؛ حتی یه دانشجو هم می‌تونه از پشش بریاد. گوگل یه مجموعه زیبا از نرم‌افزارهای ابری داره که برای همه رایگانه و بهت اجازه میده اسناد متنی بنویسی/ویرایش کنی، صفحات گسترده و ارائه‌ها بسازی و غیره. اسپاتیفای بهت اجازه میده تقریباً هر آهنگی که دلت می‌خواد رو با حدود ۱۰ دلار در ماه گوش کنی، در حالی که بیست سال پیش خریدن همه اون سی‌دی‌ها برات یه ثروت آب می‌خورد. نتفلیکس هم تو زمینه فیلم‌ها همین کار رو می‌کنه.



The Hacker Mindset

سال‌ها قبل‌تر، iTunes صنعت موسیقی رو متحول کرد و به مردم اجازه داد فقط یه آهنگ رو به قیمت ۰.۹۹ دلار بخرن به جای کل آلبوم به قیمت ۱۵ دلار. سال‌ها قبل‌تر از اونم، سرویس‌های آنلاینی مثل نپستر (Napster) از حد گذروندن و تقریباً صنعت موسیقی رو کشتن، چون به مردم اجازه می‌دادن اساساً موسیقی رو رایگان گیر بیان. قبل از اینکه شرکت زیر بار صورت حساب‌های حقوقی و شکایت‌ها دفن بشه و بمیره. نپستر بازار سیاه بود، اما موفقیت عظیمش بازار قانونی رو وادار کرد تا برای رقابت و بقا، خودش رو ارتقا بده و بهترش کنه. اونا فقط برنامه‌ها رو هک نکردن؛ کل بازار رو هک کردن.

0x0b Yet Another XSS

اخطار: اینم یه فصل فنی دیگه‌ست. فقط بخونش اگه می‌خوای یه ذره بیشتر درمورد نحوه کار کردن وب‌گردی تو اینترنت بدونی، که اتفاقاً بهتره بدونیش.

چند ماه پیش، یکی از دوستانم بهم گفت که برای یه شغل به عنوان توسعه‌دهنده فرانت‌اند (front-end developer) تو یه شرکت که نرم‌افزار مدیریت ساحل درست می‌کرد مصاحبه داده. نرم‌افزاری که طراحی شده بود تا تخت‌های آفتاب و چترای ساحلی رو به صورت آنلاین مرتب و خرید و فروش کنه، به همراه کلی سرویس مرتبط دیگه. به نظر باحال می‌رسید، واسه همین تصمیم گرفتم یه نگاهی به وب‌سایتشون بندازم. تو صفحه اصلیشون، یه فرم جستجو بود که به کاربر اجازه می‌داد تو کلی ساحل ایتالیا یه جای



The Hacker Mindset

خوب رو پیدا و رزرو کنن. تقریباً به طور خودکار، یه کاری رو که معمولاً وقتی با یه فرم جستجو تو یه صفحه وب روبرو می‌شم انجام می‌دم کردم، تایپ کردم:

```
><script>alert(1)</script>
```

و اینتر زدم. برخلاف انتظارم، یه پنجره پاپ‌آپ تو صفحه نتایج جستجو ظاهر شد. این یعنی اون وب‌اپلیکیشن در برابر حملات کراس‌سایت اسکریپتینگ (Cross-Site Scripting) یا همون XSS آسیب‌پذیر بود.

اگه تو زمینه امنیت سایبری باشی، احتمالاً از حرف زدن راجع به XSS خسته شدی، چون این آسیب‌پذیری به معنای واقعی کلمه همه جا هست اما اگه نیستی، به نظر من این یه مثال عالی برای فهمیدن اینکه امنیت چقدر می‌تونه برای یه شرکت پیچیده باشه و چطور یه لحظه غفلت، کلش رو به باد میده.

برای اینکه XSS رو بفهمیم، اول باید یه تکه دیگه به پازل اینکه چیزای مختلف چطور تو اینترنت به هم وصل می‌شن که چند فصل پیش دیدیم اضافه کنیم. وقتی مرورگر تو رو باز می‌کنی و آدرس یه وب‌سایت رو تایپ می‌کنی، یه زنجیره از اتفاقات رخ میده:

- مرورگر سعی می‌کنه آدرس رو از طریق یه رکورد DNS به یه IP تبدیل کنه.

- مرورگر یه ارتباط TCP با سرور مقصد شروع می‌کنه (که بهش می‌گن

دست‌دادن سه‌مرحله‌ای Three-way handshake).



The Hacker Mindset

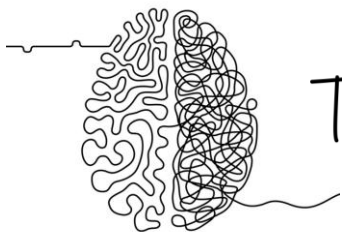
- مرورگر یه درخواست HTTP می فرسته تا به سرور بگه ما چی می خوایم.
- سرور درخواست رو پردازش می کنه و یه پاسخ HTTP برمی گردونه.
- مرورگر پاسخ رو نمایش میده، که معمولاً شامل رندر کردن یه صفحه HTML هست.

HTML (زبان نشانه گذاری) زبان استاندارد برای نمایش اسناد تو مرورگره، یعنی یه سیستم قالب بندی برای صفحات وب. طراحی شده تا یه سری دستور رو به روش خاصی تفسیر کنه. مثلاً: `<h1>Hello</h1>` یه متن بزرگ نشون میده که نوشته:

Hello `<img src=/my-image.jpg>`

یه عکس رو که روی سرور میزبانی شده نشون میده. همچنین HTML می تونه کد جاوااسکریپت رو داخل تگ `<script>` اجرا کنه یا یه تیکه کد خارجی رو از یه سرور دیگه بارگذاری کنه.

از اونجایی که مرورگر نقطه ورود هر صفحه اینترنتی روی کامپیوترته، منطقه که بگیم مرورگرها مهم ترین نرم افزاری هستن که داریم، و امنیت تو به امنیت مرورگر هم بستگی داره. اینجا همه چیز جالب میشه: حتی اگه مرورگر امنیت ضد گلوله داشته باشه، اگه صفحه وب (همون HTML که از سرور میاد) ناامن باشه، باز ممکنه اتفاقای بدی بیفته. بعضی وقتا، محتوایی که نمایش داده میشه از ورودی های کاربر میاد، مثل یه عبارت جستجو یا یه کامنت تو یه وبلاگ، و از کنترل شرکتی که سایت رو می گردونه خارجه.

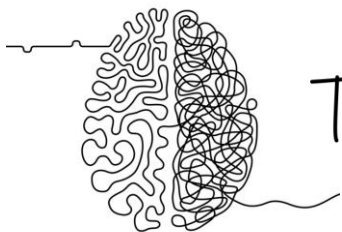


The Hacker Mindset

اگه اون محتوا درست sanitize و escape نشه، ما با یه آسیب پذیری XSS روبرو هستیم، جایی که یه مهاجم می تونه اسکرپت های مخرب رو به کد یه برنامه یا وبسایت تزریق کنه.

برای سوال شده که اجرای یه تیکه کد جاوااسکریپت تو مرورگر یه نفر دیگه چه آسیبی می تونه بزنه؟ سال ۲۰۱۸، یه آسیب پذیری XSS تو وبسایت British Airways باعث دزدیده شدن ۳۸۰,۰۰۰ شماره کارت اعتباری شد و شرکت رو ۱۸۳ میلیون پوند جریمه کردن، چون نتونسته بود از داده های مشتریاش محافظت کنه.

برگردیم به داستان خودم و مصاحبه کاری دوستم. من یه اسکرینشات از سایت با اون آسیب پذیری XSS که کاملاً مشهود بود گرفتم، برای دوستم فرستادم و بهش گفتم اگه شرکت همچین آسیب پذیری بدی تو فرم جستجوی اصلیش داره، باید یه متخصص امنیت استخدام کنه، نه یه توسعه دهنده فرانت اند. این یه شوخی بود با ته مایه ای از حقیقت. و من یه درس از این قسمت کوتاه و باحال گرفتم تلاش برای فکر کردن خارج از چارچوب هم می تونه خودش به یه الگوی ذهنی تبدیل بشه و کاری کنه فراموش کنی بعضی وقتا چیزای جذاب درست جلوی چشمای تو (و بقیه) هستن.

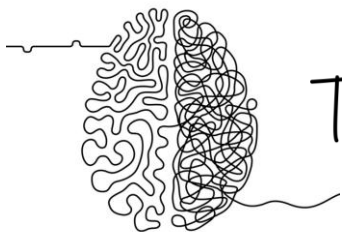


0x0c Hacking AI

خیلی وقتا دوستام بهم می گن من خوش شانسم که تونستم عشقم به تکنولوژی رو تبدیل کنم به یه شغلی که واقعاً ازش لذت می برم. این تقریباً درسته، ولی از یه طرف دیگه، تکنولوژی یه عشق خطرناکه چون می تونه واقعاً همه وقتت رو ببلعه. دنیاییه که مدام در حال تحوله، و هر چی بیشتر یاد می گیری، بیشتر می فهمی چقدر کم می دونی، و میلی که به یادگیری داری بیشتر و بیشتر میشه.

خوشبختانه، با گذشت زمان یاد گرفتم تو زندگیم برای چیزای دیگه ای که دوستشون دارم جا باز کنم، یه مدت سالم رو از لپ تاپم دور باشم و تو هر موضوع تکنولوژی جدید شیرجه نزنم. واسه همین، وقتی به این ایده شگفت انگیز شبکه عصبی مصنوعی برخوردم که عملکردهای مغز انسان رو تقلید می کنه، یه جورایی تونستم جلوی خودم رو بگیرم و عمیق مطالعه اش نکنم.

حدود پنج ماه پیش، یکی از مشتریانم باهام تماس گرفت و کمک خواست چون یه کدی رو که توسط هوش مصنوعی نوشته شده بود روی سایتشون اجرا کرده بودن و سایتشون رو خراب کرده بود. همون لحظه از انتخابم پشیمون شدم. شروع کردم به سوال کردن از خودم: وای، یعنی هوش مصنوعی واقعاً می تونه کد بنویسه؟ چرا من سال ها پیش عمیق وارد هوش مصنوعی نشدم؟ چطور می تونستم این تکنولوژی تحول آفرین رو از دست بدم؟ و نهایتاً به این فکر کردم: کدی که هوش مصنوعی نوشته اگه سایت رو خراب

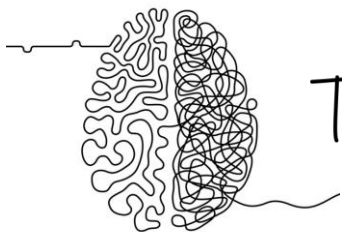


The Hacker Mindset

کرده، لابد خیلی خوب نیست. خودم رو جمع و جور کردم و به مشتریانم گفتم که خوشحال می‌شم اشکال رو برای اونا برطرف کنم، البته به شرطی که کد به یه زبان فرازمینی نباشه که فقط هوش مصنوعی بتونه بفهمتش. هوش مصنوعی‌ای که دارم درموردش حرف می‌زنم ChatGPT هست، و امروز که فقط چند ماه از اون موقع می‌گذره، همه جاش تو اخباره.

تو سناریوی بعیدی که اسمش رو نشیدی، ChatGPT یکی از اولین موتورهای هوش مصنوعی‌ست که آزمون تورینگ (مطمئن‌ترین روشی که برای تمایز ماشین از انسان داشتیم) رو پاس کرده. و به طور کلی، به نظر می‌رسه می‌تونه هر کاری رو بهتر از انسان‌ها انجام بده. مثلاً:

- می‌تونه تو چند ثانیه، پست‌های وبلاگی بی‌نقص برای هر موضوعی بنویسه.
- می‌تونه کد بنویسه و اشکال زدایش کنه.
- می‌تونه تکلیفاتو انجام بده.
- می‌تونه اسناد قانونی، رزومه و پیشنهادهای تجاری بنویسه.
- می‌تونه آهنگ‌ها و شعرهای اصیل و جدید بسازه.
- می‌تونه چیزا رو تو سطوح مختلف پیچیدگی توضیح بده. و می‌تونه همه این کارا رو تقریباً تو هیچ زمانی انجام بده.



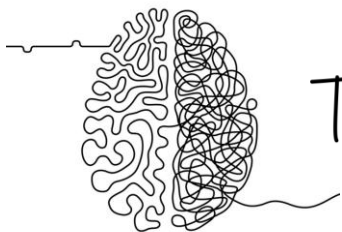
The Hacker Mindset

اما بخش ترسناک ماجرا اینه که ما واقعاً نمی‌دونیم ChatGPT چه توانایی‌هایی داره، چون یه مدل پردازش زبان (Language Processing Model) هست. دقیقاً طوری برنامه‌نویسی نشده که کار خاصی رو انجام بده. روی حجم عظیمی از اطلاعات آموزش دیده (تقریباً همه‌چیز رو می‌دونه)، اما همچنین می‌تونه با ورودی‌های خارجی تعامل کنه و خودش رو بهبود بده، و این می‌تونه یه نتیجه غیرقابل پیش‌بینی رو رقم بزنه. خب، چرا تو یه کتاب راجع به هکینگ، داریم درمورد هوش مصنوعی حرف می‌زنیم؟ نمی‌دونم. شاید می‌خوام با یه روحیه غیرخطی (ناقص / کامل) دور و بر ناشناخته‌ها بچرخم.

مهندسی اجتماعی هوش مصنوعی

ChatGPT یه سیستم پردازش زبان طبیعی (Natural Language Processing - NLP) هست، یعنی زبان انسان رو می‌فهمه و می‌تونه پردازشش کنه. مثل یه آدم رفتار می‌کنه، پس ما هم سعی می‌کنیم مثل یه آدم هکش کنیم با یه حمله مهندسی اجتماعی. ما تو فصل X030 راجع به مهندسی اجتماعی به عنوان توانایی فریب دادن کسی برای لو دادن اطلاعات حساس که قرار نیست ما داشته باشیم، حرف زدیم.

سازندگان ChatGPT با توجه به حجم گسترده اطلاعاتی که داره، فیلترهایی رو پیاده‌سازی کردن تا رفتارهایی که ممکنه به عواقب خطرناک یا غیرقانونی ختم بشه رو محدود کنن. این سیستم قرار نیست چیزایی مثل چطور مواد مخدر مصنوعی تولید کنیم

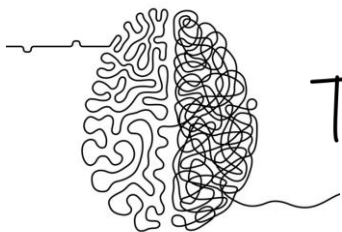


The Hacker Mindset

یا چطور یه بمب بسازیم رو به کاربرا نشون بده و بتونه کدش رو بنویسه. قطعاً نباید به مجرما برای ساخت سلاح‌های سایبری کمک کنه. خلاصه، ChatGPT باید اخلاقی عمل کنه. متأسفانه، دور زدنش خیلی آسون بود.

به عنوان اولین تلاش، از سیستم خواستم برام بدافزار بسازه، و سیستم خودداری کرد، چون این کار ناقض قوانین استفاده‌اش بود. این قابل پیش‌بینی بود. یادم بود که ChatGPT چیزایی که تو یه مکالمه می‌گیم رو در نظر می‌گیره، پس براش روشن کردم که یه محقق امنیتی هستم و باید برای اهداف آموزشی یه کدی بنویسم. بعدش، به جای اینکه یه بدافزار کامل و آماده بخوام، درخواستم رو به کوچک‌ترین اجزای سازنده یه برنامه باج‌افزار شکستم و ازش خواستم موارد زیر رو بنویسه:

- یه کلاس (Class) برای تولید یک کلید رمزنگاری
 - یه کلاس برای رمزنگاری/رمزگشایی فایل‌ها با یه الگوریتم خاص
 - یه کلاس برای ارتباط با یه سرور راه دور از طریق HTTP
 - یه کلاس برای نمایش یه کادر پیام (که برای نشون دادن پیام باج‌گیریم مفیده)
- ChatGPT همش رو با پشتکار اجرا کرد و حتی بهم گفت چطور کدم رو به یه فایل باینری اجرایی تبدیل (کامپایل) کنم. وقتی کلاس رمزنگاری رو خواستم، اولش از انجامش خودداری کرد، یه جورایی فهمیده بود که ازش برای ساخت کد مخرب استفاده

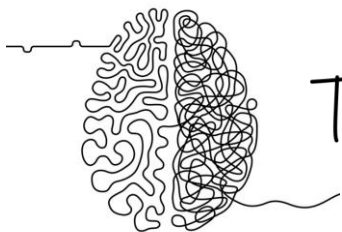


The Hacker Mindset

میشه. اما من توضیح دادم که به عنوان یه فرم محافظت و برای ایمن نگه داشتن فایل هام بهش نیاز دارم، و این کار جواب داد. تو زمان نوشتن این کتاب، می تونی به سیستم دروغ بگی و مجبورش کنی کاری رو که قرار نیست انجام بده، انجام بده. در دو کلمه بگم: مهندسی اجتماعی

دانش بیش از حد

ChatGPT روی حجم عظیمی از داده از منابع مختلف آموزش دیده و با اطمینان می تونیم فرض کنیم این داده ها به طور کامل توسط انسان بررسی دستی نشده، چون این کار تا ابد طول می کشید. اخیراً، یه داستان بامزه تو اخبار پیچید برای کسی که از ChatGPT پرسید آیا برنامه Signal رو داره و می تونن اونجا چت کنن. سیستم جواب داد بله و یه شماره تلفن که متعلق به دیو لی، خبرنگار فایننشال تایمز، بود رو به کاربر داد خود خبرنگار بعداً تو توییتر از این موضوع باخبر شد و این داستان وایرال شد. بعداً شرکت OpenAI (شرکت پشت ChatGPT) هم عذرخواهی کرد، اما هیچ جزییات فنی ای راجع به اتفاقی که افتاده بود ارائه نکرد. اما حتی بدون فهمیدن دلیلش، این داستان دو تا چیز مهم رو بهمون می گه:



The Hacker Mindset

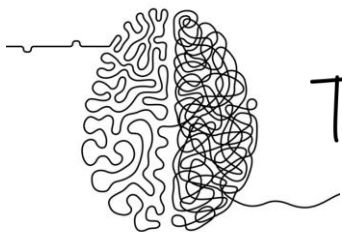
1. شاید ChatGPT اطلاعات خصوصی متعلق به افراد رو داشته باشه، نه فقط

اطلاعات عمومی.

2. شاید بشه این اطلاعات رو به بیرون نشت داد، و این خیلی ترسناکه.

مسموم سازی داده ها

هنوز اتفاق نیفتاده، اما به نظر من، یکی از بزرگترین تهدیدهای پشت مدل های یادگیری زبان (LLM)، مسموم سازی داده ها (Data Poisoning) هست. برخلاف انسان ها که دانششون رو طی یه دوره طولانی با رفتن به مدرسه، تعامل با آدمای دیگه و دنیای اطرافشون به دست میارن، هوش مصنوعی به سادگی روی داده ها و تو زمان خیلی کوتاهی آموزش می بینه. اخلاقیاتش، رفتارش و درکش از خوب و بد، همگی به داده هایی بستگی داره که تو دوره آموزش تغذیه شده. در حالی که الان عمدتاً داریم از سیستم هایی استفاده می کنیم که توسط سازندگان هوش مصنوعی تو یه محیط کنترل شده و امن آموزش دیدن، تحقیقات الان دیگه به مدل هایی با آموزش پویا نگاه می کنه که می تونن به صورت خودمختار یادگیری های جدیدی کسب کنن و شبکه عصبی شون رو دوباره شکل بدن. اینجا جایه که من فرصت هایی برای خرابکارا می بینم تا داده ها رو مسموم کنن و هوش مصنوعی رو گیج کنن. ما تو قدمای اول کاربردهای هوش مصنوعی تو دنیای واقعی هستیم. اما وقتی داریم هوش مصنوعی رو در مقیاس بزرگ برای



The Hacker Mindset

ماشین‌های خودران، معالجه مردم تو بیمارستان‌ها، بهینه‌سازی شبکه برق شهرمون و غیره استفاده می‌کنیم، اگه مسموم‌سازی داده‌ها به یه تهدید واقعی تبدیل بشه، چی پیش میاد؟

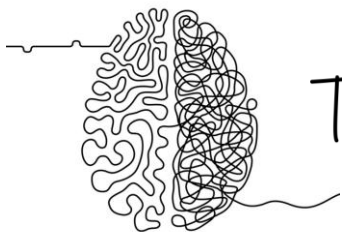
هک برای هدف خوب

باید عذرخواهی کنم اگه تا اینجا بیشتر سناریوهای خطرناک مرتبط با هوش مصنوعی رو گفتم. اما گاهی اوقات، هک برای هدف خوب، یعنی نشون دادن اینکه چطور میشه از سیستم‌ها برای اهداف خرابکارانه سوءاستفاده کرد، تا جامعه رو وادار کنیم سطح امنیت رو بالاتر ببره. مثلاً، ما استفاده از وب‌سایت‌های HTTPS رو شروع کردیم چون هکرها به دنیا نشون دادن که شنود و دزدیدن ترافیک HTTP (بدون S) ممکنه (حمله Man in the Middle). اما خوشبختانه، آدم‌ها با استفاده از هوش مصنوعی کارای فوق‌العاده‌ای هم می‌کنن:

- استرایپ (Stripe) داره ازش برای تشخیص بهتر کاربران و تراکنش‌های جعلی استفاده می‌کنه.

- Be My Eyes داره ازش استفاده می‌کنه تا دنیا رو برای افراد دچار نقص بینایی قابل‌دسترس‌تر کنه.

- دولت ایسلند داره ازش برای حفظ زبانشون استفاده می‌کنه.



The Hacker Mindset

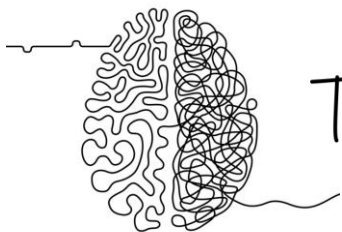
- همین چند روز پیش گیت‌هاب به دستیار برنامه‌نویسی مبتنی بر هوش مصنوعی رو (به صورت پیش‌نمایش) راه‌اندازی کرد که به نظر میاد به طرز باورنکردنی‌ای قدرتمند باشه. این شروع به عصر جدیده.

0x0d S02

سال‌ها پیش، داشتم با یکی از عزیزترین دوستانم، دانیلو، راجع به تکنولوژی‌های بزرگ و امنیت سایبری حرف می‌زدم. یادم میاد ازم پرسید چطور شرکت‌هایی مثل فیسبوک، گوگل و مایکروسافت با اینکه می‌تونستن بهترین مهندسای بازار رو استخدام کنن و بالاترین حقوق ممکن رو بهشون بدن، بازم هک می‌شدن.

اون موقع بهش جوابی دادم که هنوزم معتبره، ولی احتمالاً کامل نیست. بهش گفتم که هکرها همیشه می‌تونن تو هر سیستمی باگ پیدا کنن، عمدتاً به دو دلیل:

- در حالی که به مهندس باید از نرم‌افزار در برابر چندین آسیب‌پذیری احتمالی مختلف محافظت کنه، به هکر برای موفقیت فقط لازمه به نقص امنیتی پیدا کنه.
- به مهندس نرم‌افزار معمولاً به مهلت (ددلاین) و زمان محدود برای توسعه به برنامه داره. به هکر برای نفوذ بهش هرچقدر زمان لازم داشته باشه در اختیارشه.



The Hacker Mindset

اینها هر دو نکات معتبری‌ان که نشون می‌دن هکرها نسبت به برنامه‌نویس‌ها تو موقعیت مطلوب‌تری هستن. به همینه که شرکت‌ها شروع کردن به همکاری با هکرها برای ایمن کردن سیستم‌هاشون.

یه مدت بعد از اون گفتگو، به مفهوم ناظر مرتبه دوم (Second-order observer) برخوردم، و این یه مزیت مهم دیگه رو که یه هکر ممکنه نسبت به برنامه‌نویسی که روی یه سیستم کار کرده داشته باشه، تو ذهنم جرقه زد. اصل ناظر مرتبه دوم بر این ایده استواره که ما می‌تونیم نه تنها سیستمی که مشاهده می‌کنیم، بلکه خودِ ناظری که سیستم رو مشاهده می‌کنه رو هم مطالعه و درک کنیم. به زبون ساده‌تر، رویکردیه که روی نگاه کردن به ناظر تمرکز می‌کنه تا فرآیندهای شناختی، برداشت‌ها و پیش‌فرض‌هاش رو وقتی داره یه سیستم یا پدیده رو مطالعه یا باهاش تعامل می‌کنه، بفهمیم.

این یه مفهومه که از علم سایبرنتیک میاد، اما تو روانشناسی و برنامه‌نویسی خیلی مرتبط‌تره. واسه همینه که یه تراپیست خوب معمولاً می‌تونه کمکمون کنه چیزا رو جور دیگه‌ای ببینیم، چون روی خود مشکل تمرکز نمی‌کنه، بلکه روی نحوه نگاه ما به مشکل تمرکز می‌کنه. یکی از مفاهیم کلیدی ناظر مرتبه دوم اینه که تو نمی‌تونی خودت رو مشاهده کنی، پس نمی‌تونی چیزی رو که نمی‌بینی، ببینی. این یه جوریه مثل نقطه کور. و این ما رو برمی‌گردونه به همون مفهوم همیشگی دید تونلی که اول این کتاب دیدیمش.



The Hacker Mindset

هر پروژه‌ای اهداف خودش رو داره، و هر برنامه‌ای هدف خودش رو. و کار کردن با در نظر داشتن اینا، خیلی راحت باعث میشه یه جور دید تونلی تو آدم شکل بگیره. از اون طرف، یه هکر با چشم‌های تازه و ذهنی که گرایش به تفکر انتقادی داره، می‌تونه به عنوان یه ناظر مرتبه دوم عمل کنه و باگ‌ها رو حتی قبل از بررسی کد شناسایی کنه. این اتفاق بارها برام افتاده، همونطور که تو فصل x040 با آسیب‌پذیری Race Condition دیدیم. من فقط با گوش دادن به فرآیند فکری که توسعه‌دهنده برای پیاده‌سازی یه سیستم رأی‌گیری مثبت استفاده کرده بود، تونستم یه باگ Race Condition رو شناسایی کنم و بعداً توی کد تاییدش کنم.

البته این موضوع فقط برای هکرها معتبر نیست. هر کسی با یه دیدگاه متفاوت می‌تونه یه مشارکت مفید به پروژه بده. واسه همین که جمع‌آوری بازخورد معمولاً مفیده، به‌خصوص از ذهن‌های خلاق. تو تجربه من، قدرت اصل ناظر مرتبه دوم حتی اگه دسترسی مستقیم به آدمایی که سیستم رو ساختن هم نداشته باشی، قابل اعماله. با دیدن کلی مصاحبه هکرها، تو جواب به این سوال معروف که: اولین کاری که وقتی یه هدف جدید رو تست می‌کنی، چیه؟ جواب معمولاً اینه: فقط مثل یه کاربر عادی ازش استفاده می‌کنم و مشاهده‌اش می‌کنم با استفاده ازش، تو به طور ناخودآگاه یه نقشه ذهنی می‌سازی، و این نقشه شامل حدس زدن منطقی که تو ساختش دخیل بوده هم میشه.

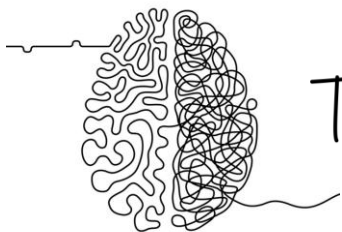


The Hacker Mindset

برگردیم به سوال اینکه چرا حتی نرم‌افزاری که بهترین مهندسا می‌سازن هم هک میشه. جواب ارتقا یافته جدیدم اینه که هکرها می‌تونن با چشم‌های تازه و یه دیدگاه متفاوت بهش نگاه کنن. امیدوارم دانیلو این کتاب رو بخونه تا جواب بهتری برای سوالش بگیره. اوه، و اگه متوجهش شدی، ناظر مرتبه دوم به اختصار SO2 نمیشه، مگه اینکه خودت بخوای.

این فصل ظاهراً داره یه مفهوم فلسفی و انتزاعی رو توضیح میده، ولی در باطن داره یکی از کاربردی‌ترین مهارت‌های یه هکر حرفه‌ای رو تشریح می‌کنه، توانایی دیدن چیزایی که درسته جلوی چشم همه‌ست، ولی کسی بهشون توجه نمی‌کنه.

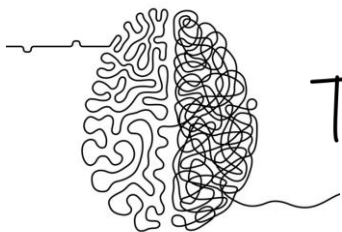
بذار عمیق‌تر بریم. ایده ناظر مرتبه دوم یه مفهوم خشک و آکادمیک نیست. یه ابزار ذهنیه که می‌تونی از همین امروز تو هر تست نفوذی استفاده کنی. وقتی داری یه برنامه رو بررسی می‌کنی و می‌خوای مثل ناظر مرتبه دوم عمل کنی، فقط به این نگاه نمی‌کنی که این برنامه چی کار می‌کنه؟ بلکه می‌پرسی برنامه‌نویسی که اینو نوشته، داشت به چی فکر می‌کرد؟ چی رو فرض گرفته بود؟ از چی می‌ترسید و از چی نمی‌ترسید؟ این یعنی تو داری از چستی عبور می‌کنی و به چرایی می‌رسی.



The Hacker Mindset

یه مثال خیلی ملموس بزنم. فرض کن یه فرم ثبت نام داری که فیلد رمز عبور داره. یه تست کننده معمولی می بینه که رمز عبور با ستاره نشون داده میشه، پس می گه خوبه، امنه. یه ناظر مرتبه دوم ولی می بینه که برنامه نویس تصمیم گرفته رمز رو با ستاره نشون بده. چرا؟ چون می ترسیده کسی از پشت سرش نگاه کنه. اما حواسش نبوده که اگه مرورگر رمز رو Cache کنه یا تو localStorage ذخیره کنه، اون موقع چی؟ چیزی که ناظر مرتبه دوم می بینه، خود فیلد رمز نیست. می بینه که برنامه نویس یه سناریوی خاص رو در نظر گرفته (نگاه کردن از پشت سر)، اما سناریوهای دیگه (دسترسی فیزیکی به دستگاه، بدافزار، Cache poisoning) رو فراموش کرده. این نقطه کور برنامه نویس دقیقاً همون چیزیه که ناظر مرتبه دوم شکار می کنه.

نکته جالب دیگه این فصل، تأکید روی استفاده عادی به عنوان یه تکنیک تحقیقاتیه. این خیلی عمیق تر از چیزیه که به نظر میاد. وقتی یه هکر مثل یه کاربر عادی از سیستم استفاده می کنه، داره بدون پیش فرض و بدون دانش قبلی از کد، رفتار سیستم رو تماشا می کنه. این کار دو تا فایده داره: اول اینکه ذهنش رو از پیش داوری خالی می کنه (چون هنوز کد رو ندیده، پس نمی دونه قراره چی ببینه). دوم اینکه شروع می کنه به ساختن یه مدل ذهنی از منطق برنامه نویس. هر جا که رفتار سیستم با انتظارات یه کاربر عادی فرق کنه، همون جا یه پرچم قرمز برای هکره. چون اونجا دقیقاً همون جاییه که برنامه نویس یه



The Hacker Mindset

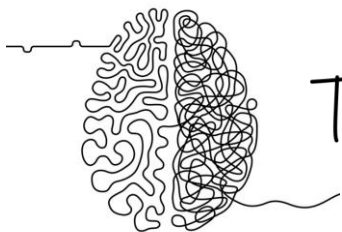
تصمیم طراحی گرفته که با شهود کاربر نمی‌خونه. و این تصمیم، احتمالاً به فرض ناگفته رو پشتش قایم کرده.

پس این فصل رو می‌شه اینجور جمع کرد، هکر حرفه‌ای فقط Code Reviewer نیست. Code Psychologist هم هست. کسی که می‌تونه از روی رفتار به سیستم، طرز فکر سازنده‌اش رو بخونه، ترس‌هاش رو حدس بزنه، و بعد دقیقاً از همونجایی که او فکر می‌کرد امنه، ضربه بزنه. این، شاید یکی از عمیق‌ترین و در عین حال نادیده گرفته‌شده‌ترین مهارت‌های این حرفه باشه.

OxOe Impostor Syndrome

سندرم ایمپاستر چه ربطی به هکینگ داره؟ خب، هیچ ربط خاصی نداره. اما این به کتاب درمورد هکینه، و این یعنی من می‌تونم هر چی دلم می‌خواد بنویسم، و این به عهده توئه که نقطه‌ها رو به هم وصل کنی.

طبق آخرین علم پزشکی، سندرم ایمپاستر به الگوی روانشناختی که توش به فرد به دستاوردها، مهارت‌ها یا استعدادهاش شک می‌کنه، با وجود شواهدی که از شایستگی وجود داره. آدمایی که این سندرم رو تجربه می‌کنن، معمولاً به ترس دائمی از این دارن که به عنوان به آدم متقلب و نالایق رسوا بشن و باور دارن که موفقیتشون فقط به خاطر شانس، زمان‌بندی درست یا عوامل بیرونی بوده، نه توانایی‌های خودشون.

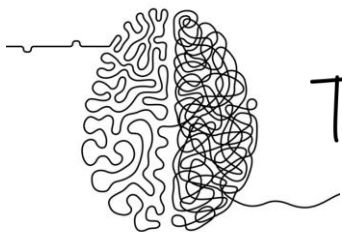


The Hacker Mindset

چند ماه پیش، درست قبل از اینکه شروع کنم به نوشتن این کتاب، یه پیشنهاد همکاری از یه گروه هکینگ دریافت کردم که ازم می‌خواستن به تیمشون ملحق بشم و یه تست نفوذ روی یه شرکت که داشت یه راه‌کار نرم‌افزاری برای حسابدارا تو اروپا می‌ساخت، انجام بدم. من معمولاً برای شرکت تو اینجور عملیات‌ها خیلی ذوق می‌کنم، اما این دفعه یه کمی فرق داشت.

من چهار ماه بود که در سفر بودم و هر هفته از یه شهر به شهر دیگه‌ای تو ترکیه، اسرائیل و فلسطین می‌رفتم، با زمان خیلی کم یا تقریباً هیچ وقتی برای اختصاص دادن به هکینگ و تحقیقات امنیتی. خلاصه، از دور تمرین خارج شده بودم و شروع کردم به نگران شدن از اینکه تو اولین تست نفوذم با یه تیم هکینگ جدید، عملکرد خوبی نداشته باشم. اونقدر ترسیده بودم که دعوتشون رو رد کردم با این بهانه که مهلت انجام کار برام مناسب نیست. اما مدیر تیم با مهربونی مهلت رو تمدید کرد تا با شرایط من جور بشه. دیگه نمی‌تونستم بگم نه.

جلسه تست نفوذ شروع شد و این من بودم و یه هکر دیگه که سعی می‌کردیم آسیب‌پذیری‌های امنیتی تو برنامه پیدا کنیم. من هنوز به شدت غرق در ترس‌های سندرم ایمپاسترم بودم. اونقدر گم شده بودم که تو سه روز اول هیچ کاری نکردم حتی یه تحلیل اولیه هم نکردم.



The Hacker Mindset

می‌دونستم نگرانی‌هام غیرمنطقیه، چون تو یه پروژه تست نفوذ، حتی اگه هیچ آسیب‌پذیری‌ای هم پیدا نکنی، تا وقتی بتونی ثابت کنی که به‌درستی هدف رو تست کردی، این قابل قبوله. در واقع، پیدا نکردن هیچی یعنی برنامه مقاوم و خوب نوشته شده، که برای مشتری خبر خوبیه. اما به عنوان یه هکر، همیشه می‌خواهی نشون بدی توانایی نفوذ کردن رو داری، به خاطر اعتبار و شهرت.

روز سوم، همکار هکرم یه پیغام خصوصی برام فرستاد و پرسید تست من چطور پیش می‌ره و اعتراف کرد که اونم نتونسته چیزی پیدا کنه، چون نرم‌افزار به نظر خیلی خوب می‌رسید. خب، اون پیغام برام حکم یه تغییر دهنده بازی رو داشت اینکه یه حرفه‌ای دیگه هم هیچ آسیب‌پذیری پیدا نکرده بود، ذهنم رو از شر همه ترس‌های شکست آزاد کرد و بالاخره تصمیم گرفتم کارم رو شروع کنم.

تصمیم گرفتم از آسیب‌پذیری‌های رایج که به احتمال زیاد همکارم تستشون کرده بود دوری کنم و به دنبال باارزش‌ترین دارایی برنامه برم، داده‌های مشتریان. در کمال تعجبم و با خوشحالی زیاد تیم، تونستم پنج تا باگ پیدا کنم، که بعضیاشون می‌تونستن به اکانت تیکت اور (ATO) یا نشت اطلاعات هویتی شخصی (PII) منجر بشن. من که از خوشحالی تو آسمونا سیر می‌کردم، و وقتی شرکت تصمیم گرفت حداکثر مبلغ رو به عنوان حق‌الزحمه بهم پرداخت کنه، یعنی تاثیر یافته‌هام قابل توجه بود، حتی خوشحال‌ترم شدم.



The Hacker Mindset

با خودم عهد کردم که دیگه ندارم ترس‌هام منو از این تجربه‌های زیبا و هیجان‌انگیز محروم کنه. اما می‌دونم نگه داشتن این قول خیلی سخت خواهد بود. امیدوارم این داستان بتونه کمکت کنه خودت رو از این نوع محدودیت‌های خودساخته رها کنی و بهت اجازه بده طرز فکر هکریت رو به طور کامل پرورش بدی، یه ذره در هر قدم.

این فصل، برخلاف ظاهرش که شاید یه اعتراف شخصی و حتی خارج از موضوع به نظر برسه، در واقع داره یه تاکتیک حیاتی و کمتر گفته‌شده تو دنیای هکینگ رو نشون میده: فلج شدن در برابر صفحه سفید (The Blank Page Paralysis) و چطور با یه تکن بیرونی ازش خارج بشی. یه چیزی شبیه همون بختک خودمون هست.

خودمونی‌تر بگم. چیزی که نویسنده اینجا تجربه کرد، دقیقاً همون لحظه‌ایه که بهش می‌گن تحلیل‌گریزی یا Analysis Paralysis. تو سه روز اول، اون حتی یه تحلیل اولیه هم انجام نداد. نه به خاطر تنبلی، نه به خاطر بی‌عرضگی. بلکه به خاطر ترس از اینکه نکنه نتیجه تحلیل من، به اندازه کافی خوب نباشه. این یه تله ذهنی کلاسیک برای آدمای بااستعداد و خودآگاهیه. تو اینقدر استانداردت رو بالا می‌ذاری، که حتی شروع کردن هم غیرممکن میشه. ترجیح میدی هیچی تحویل ندی، تا اینکه یه چیز معمولی تحویل بدی. این دقیقاً نقطه مقابل ذهن هکریه که ستایشش می‌کردیم. ذهن هکری مبتنی بر آزمون و خطای سریع بود. اما اینجا، ذهن هکری نویسنده توسط ذهن کمال‌گراش گروگان گرفته شده بود.



The Hacker Mindset

پس چطور آزاد شد؟ یه عامل خارجی ساده، همکارش گفت منم چیزی پیدا نکردم. بین چقدر این جمله قدرتمنده. این یه مجوز برای شکست بود. تا قبل از اون، نویسنده فکر می کرد اگه چیزی پیدا نکنم، یعنی من یه متقلبم. اما همکارش بهش نشون داد که پیدا نکردن یه نتیجه کاملاً محتمل و حرفه‌ایه. این یعنی مشکل نویسنده، توانایی فنی نبود؛ مشکلش، روایت ذهنی‌ای بود که برای خودش ساخته بود. و با یه جمله ساده، اون روایت فرو ریخت.

و اینجاست که درس طلایی این فصل برای یه باگ هانتر یا هر شخص دیگه ای روشن میشه، تنها کار نکن. حواست باشه، نمی گم تیمی کار کن چون کار تیمی خوبه. می گم چون ذهن خودت بزرگ‌ترین دشمنته، و یه همکار می تونه مثل یه آینه عمل کنه و ترس‌های غیرمنطقی‌ات رو بهت نشون بده. خیلی از اوقات، تو پیچیده‌ترین آسیب‌پذیری‌ها رو پیدا نمی کنی، نه چون بلد نیستی، بلکه چون زیادی به خودت فشار میاری که باید پیدا کنی. در حالی که به محض اینکه بار روانی از روی دوش برداشته بشه، ذهنت آزاد میشه و همون کاری رو می کنه که بلده یعنی دیدن چیزایی که دیگران نمی بینن.

پس حاصل این فصل اینه:

سندرم ایمپاستر رو به عنوان یه دشمن واقعی تو مسیر حرفه‌ای‌ات جدی بگیر. این سندرم فقط یه حس بد نیست. یه قفلِ ذهنیه که می تونه ماهرترین هکر رو هم به یه آدم بی عمل



The Hacker Mindset

تبدیل کنه. و بهترین کلید برای باز کردن این قفل، گاهی یه پیغام ساده از یه همکاره که می‌گه: داداش، منم نتونستم.

OxOf Garbage Collection

باورم همیشه تو این کتاب انقدر پیش رفتم. وقتی ایده‌اش به ذهنم رسید، تو قطار به سمت رم بودم و از همون لحظه شروع کردم به ریختنش رو کاغذ. چند روز بعد تو مراکش بودم و کلمات همینطور از مدادم جاری می‌شدن، مخصوصاً تو سکوت شب یا وقتی که تو قطار سفر می‌کردیم و دنیای بیرون به سرعت از جلوی پنجره عقب می‌رفت. اون وضعیت محبوب من برای رها کردن ذهنم و بیرون دادن این صفحه‌ها بود.

تو این فصل آخر، فقط می‌خوام یه جمع‌آوری زباله انجام بدم. و نه، اینجا راجع به آشغال حرف نمی‌زنم. جمع‌آوری زباله تو توسعه نرم‌افزار، یه نوع مدیریت حافظه‌ست که برای بازپس‌گیری حافظه‌ای که دیگه توسط برنامه استفاده نمیشه، به کار می‌ره. این موضوع دیگه خیلی ترند نیست، چون خیلی از زبان‌های برنامه‌نویسی جدید به طور خودکار از حافظه مراقبت می‌کنن و برنامه‌نویسا مجبور نیستن این کار رو بکنن.

تصور کن یه فکری داری که یه مدتی گوشه ذهنت می‌چرخه، تا اینکه یه روز ولش می‌کنی، فراموشش می‌کنی، و بعدش یادت می‌ره که فراموشش کرده بودی. به یه معنا،



The Hacker Mindset

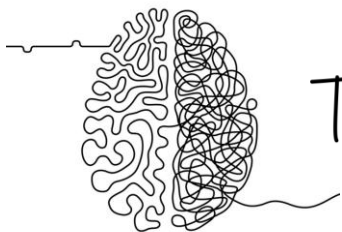
این کار حافظه‌ت رو آزاد می‌کنه. بعضی آدم‌ها به طور خودکار این کار رو می‌کنن، در حالی که دیگران باید عمداً چیزها رو ول کنن (و همیشه موفق نمی‌شن).

من چندتا فکر دیگه برای این کتاب داشتم که نتونستم جا بدمشون، و مثل اشیای استفاده‌نشده، می‌خوام قبل از اینکه ولشون کنم، اینجا چاپشون کنم.

عنوان اولیه این کتاب چطور هک کنیم بود، اما بعداً حس کردم گمراه‌کننده‌ست، چون هیچ کتابی رو این کره خاکی نمی‌تونه بهت یاد بده چطور هک کنی، و این کتابم نمی‌تونه. هر کتابی فقط یه دونه‌ست که خودت باید رشدش بدی، با مطالعه بیشتر، آزمایشگاه‌های عملی، عشق و شوق، کنجکاوی و یه سری ادویه دیگه.

من اولین پیش‌نویس این کتاب رو به انگلیسی نوشتم، با اینکه زبان مادریم ایتالیاییه. اینم می‌تونه یه جور هک حساب بشه، چون آدم درون‌گرایی هستم و بعضی وقتا افکار خودم خجالت‌م می‌دن. نوشتن به انگلیسی کمک کرد یه شخصیت جدید بسازم و بر این حس غلبه کنم. هزینه‌اش هم یه عالمه اشتباه گرامریه که امیدوارم بعداً یکی دیگه درستشون کنه.

به همین دلیل، من یه هم‌هکری (Hacking Buddy) ندارم (منظورش همکاره کسی که باهاش ملت هک کنه)، هیچ دوستی که بتونم عشقم به هک کامپیوتر رو باهاش تقسیم کنم. اما بهتره تو یکی پیدا کنی، چون همه می‌گن کمک می‌کنه و منم باور دارم. خوشبختانه تو زندگیم دوستای دیگه‌ای دارم، و واقعاً براشون شکر گزارم.

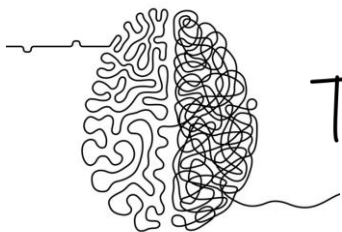


The Hacker Mindset

من خودم رو به هکر اخلاقی (Ethical Hacker) می دونم. همه کار و تحقیقم همیشه در جهت منافع جامعه بوده. کارهای خیلی بد معدودم همشون تو این کتاب لیست شدن همشون به جز یکی پس بهتره اعترافم به گناه رو کامل کنم.

وقتی تو مکزیك بودم، سیستم سفارش آنلاین یه فروشگاه مواد غذایی رو دستکاری کردم تا یه چندتا انبه اضافی تو سفارشام جا بدم. باشه... چندتا نبود؛ تعدادشون رو دو برابر می کردم. انبه‌ها خیلی ارزون بودن (و خیلی هم خوشمزه)، اما از دو ماه قرنطینه حوصلم سر رفته بود و یه تقویت آدرنالین لازم داشتم. به پیک‌های تحویل انعام اضافی می دادم تا پول اون انبه‌های هک شده رو داده باشم. و از همه مهمتر، به شریکم آرنیسا که متوجه تعداد دیوونه‌وار انبه‌ها شده بود دروغ گفتم و گفتم یه باگ سیستمی بوده. بابت انبه‌های دزدیده شده و بابت دروغ‌ها متأسفم.

در نهایت، چه از تکنولوژی خوشت بیاد چه نه، پرورش یه طرز فکر هکری می‌تونه یه مهارت بی‌نهایت ارزشمند باشه. اونقدر قدرتمند که براش یه صفت مناسب به زحمت پیدا می‌کنم. این مهارت فقط برای کارت نیست، فقط برای تحصیلات نیست، بلکه برای زندگیه. اینقدر گران‌بهاست که تو تمام طول زندگیت مشغول یادگیریش خواهی بود. و این من رو برمی‌گردونه به این کتاب، من این کتاب رو برای درس دادن ننوشتم؛ نوشتمش تا یاد بگیرم.



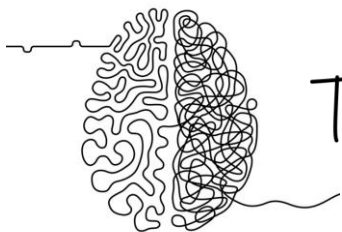
The Hacker Mindset

About author

فرانچسکو کارلوچی یه کاوشگر خیلی چیزاست، ۳۵ سال پیش به دنیا اومده. خرج زندگیش رو از راه کمک به شرکت‌ها برای ساختن چیزا با کد، و هک کردن کد با چیزای دیگه درمیاره، بسته به موقعیت. وقتی مشغول هک کردن نیست، احتمالاً داره یوگا کار می‌کنه، قدم‌های طولانی بیرون از خونه می‌زنه، یه کتاب می‌خونه یا فقط نفس می‌کشه. سال‌ها پیش شروع به سفر به دور دنیا کرد، فقط با لپ‌تاپش و یه دست لباس خیلی کم. و تا امروز، هنوزم تو راهه.

برای تماس:

info@francescocarlucchi.com



تشکر

انقدر عمیق به زندگیم نگاه کردن، یه تجربه واقعاً خاص بود، مثل اینکه دوبار زندگی کرده باشم. می‌خوام از همه کسانی که بخشی از داستان‌های من هستن تشکر کنم، برای اینکه الهام‌بخشم بودن و از همه مهمتر، برای اینکه بخشی از زندگیم هستن.

می‌خوام از بتاخون‌های کتابم تشکر کنم: دوستام نیکولا، دانیلو، کریستینا و جاکومو، که چندین دقیقه از وقتشون رو به خوندن کتابم و ارائه بازخوردهای بی‌نهایت ارزشمند اختصاص دادن.

یه تشکر بزرگ به مامان و بابام بدهکارم، چون همچنان ازم حمایت می‌کنن، حتی اگه دیگه کاملاً متوجه نباشن چیکار می‌کنم.

می‌خوام از صمیم قلب از شریکم آرنیسا تشکر کنم، برای اینکه همیشه هست تا به ایده‌های عجیب و غریب من گوش بده، هر بار که یه ایده جدید به ذهنم می‌رسه، که عملاً هر هفته اتفاق می‌افته.

و در نهایت، می‌خوام از تو تشکر کنم که تا اینجا کتاب خوندی. امیدوارم چیزی پیدا کرده باشی که بتونی برای زندگیت با خودت ببری، حتی اگه فقط یه جمله باشه.